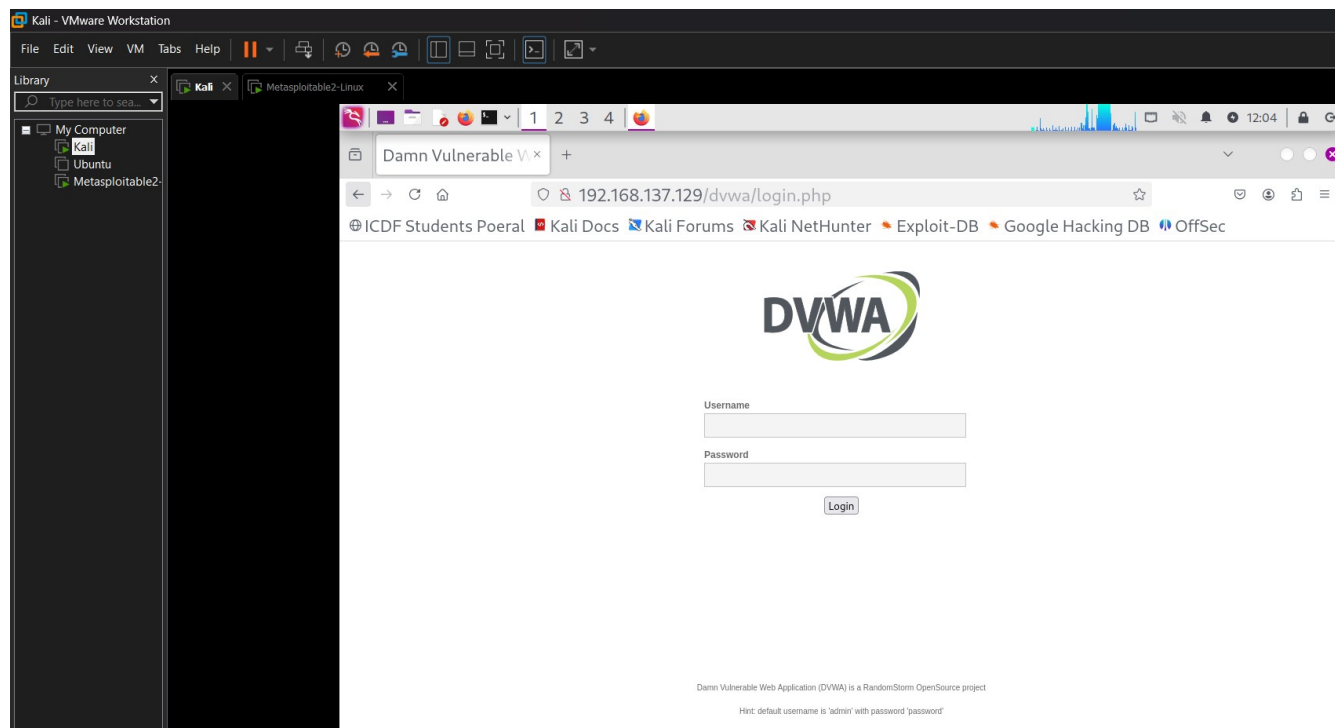


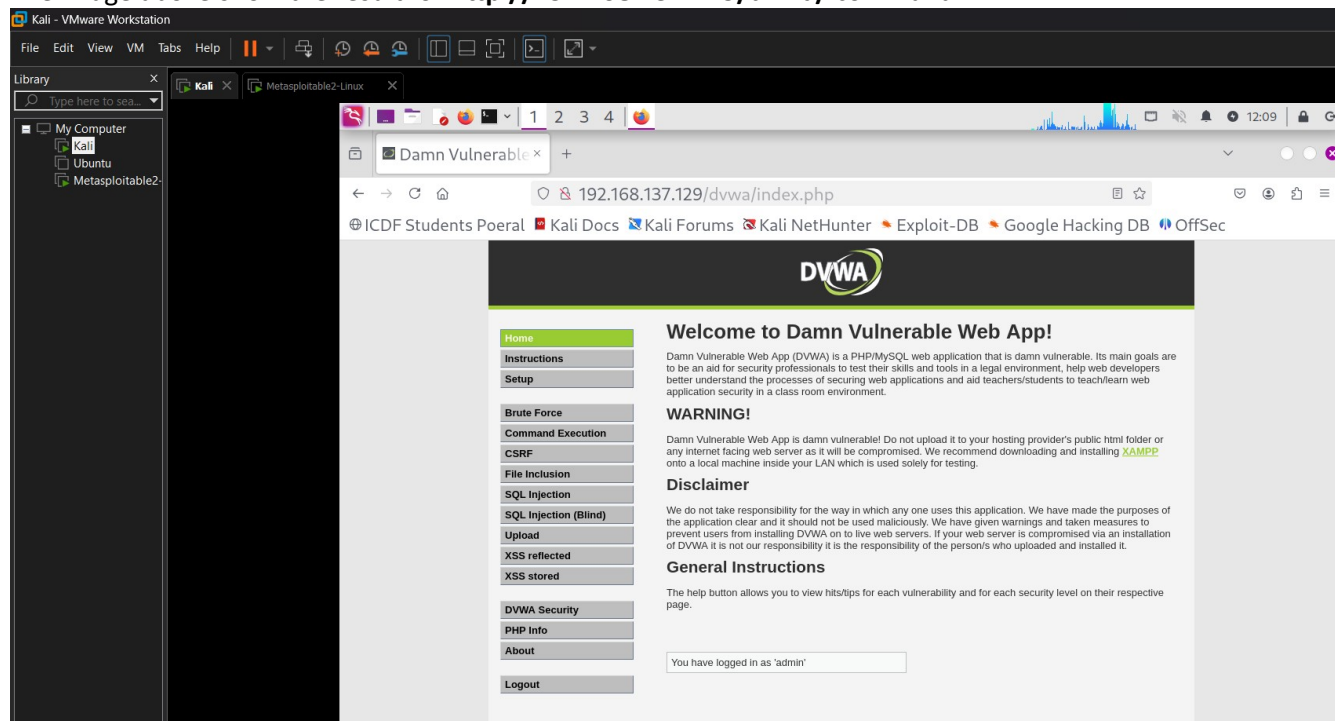
ICDFA
Linux I
WADF-2026-M04 Assignment

FULLNAME: SULEIMAN ABBEY BELLO
REGISTRATION NUMBER: C11/26/FCDF/17136
LINUX DISTRIBUTION/VERSION: ICDFA Kali Linux 2025.1
VM HOSTNAME: VMware Workstation Pro
WEEK: 10 (TEN) ASSIGNMENT

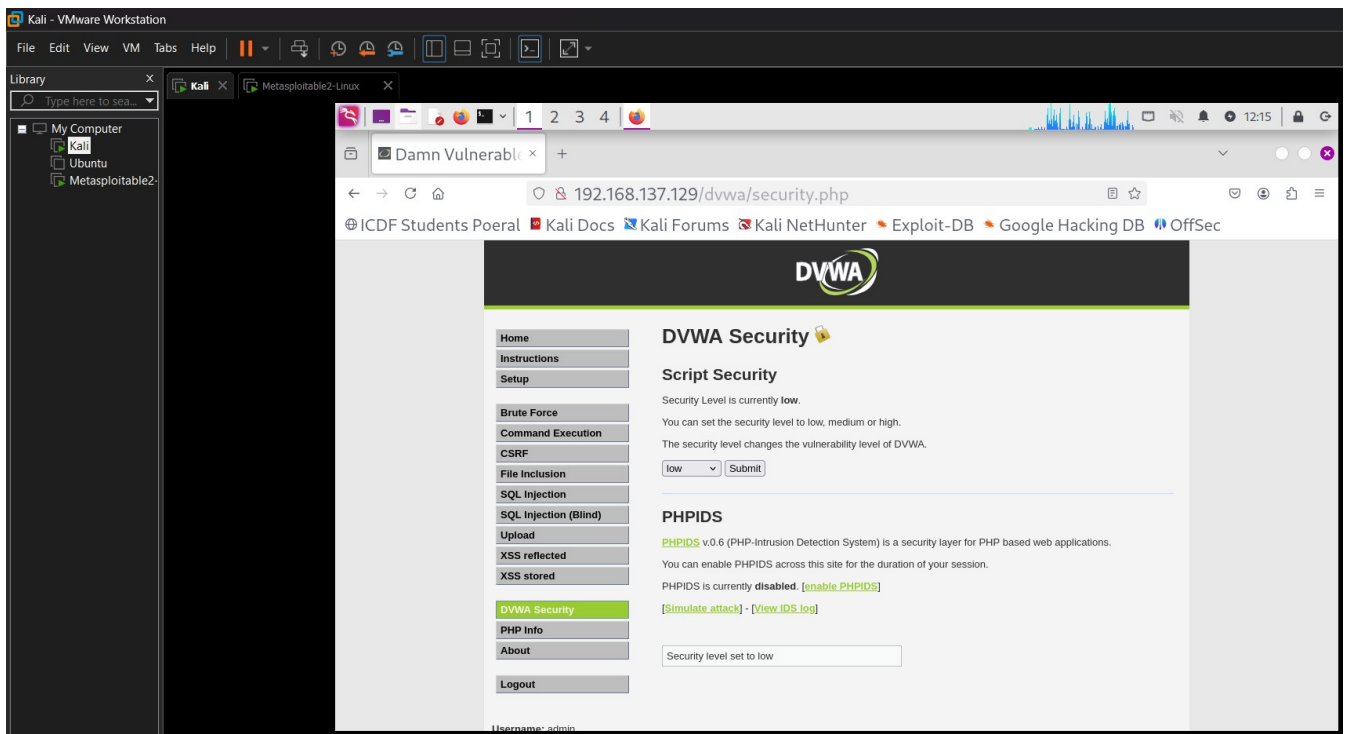
LAB 2 ASSESSMENT: Web Application Security Testing



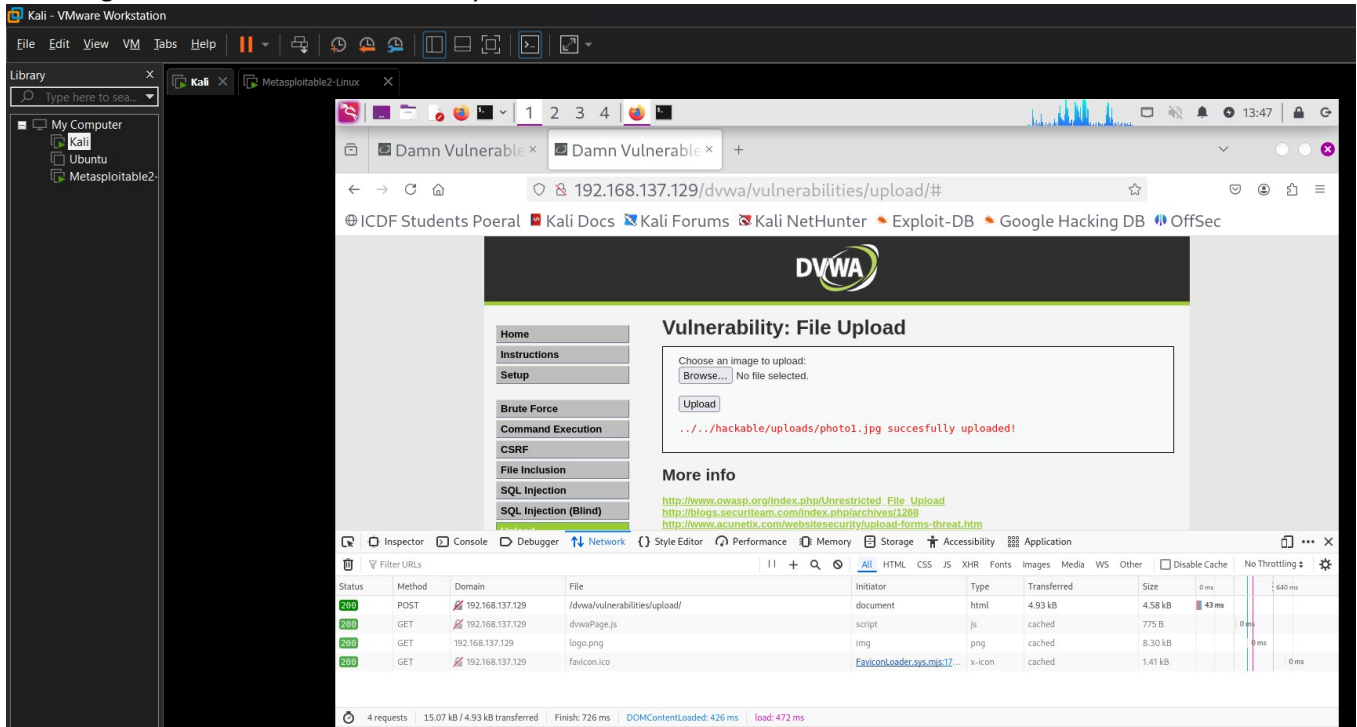
The image above show the result for **http://192.168.137.129/dvwa/** command.

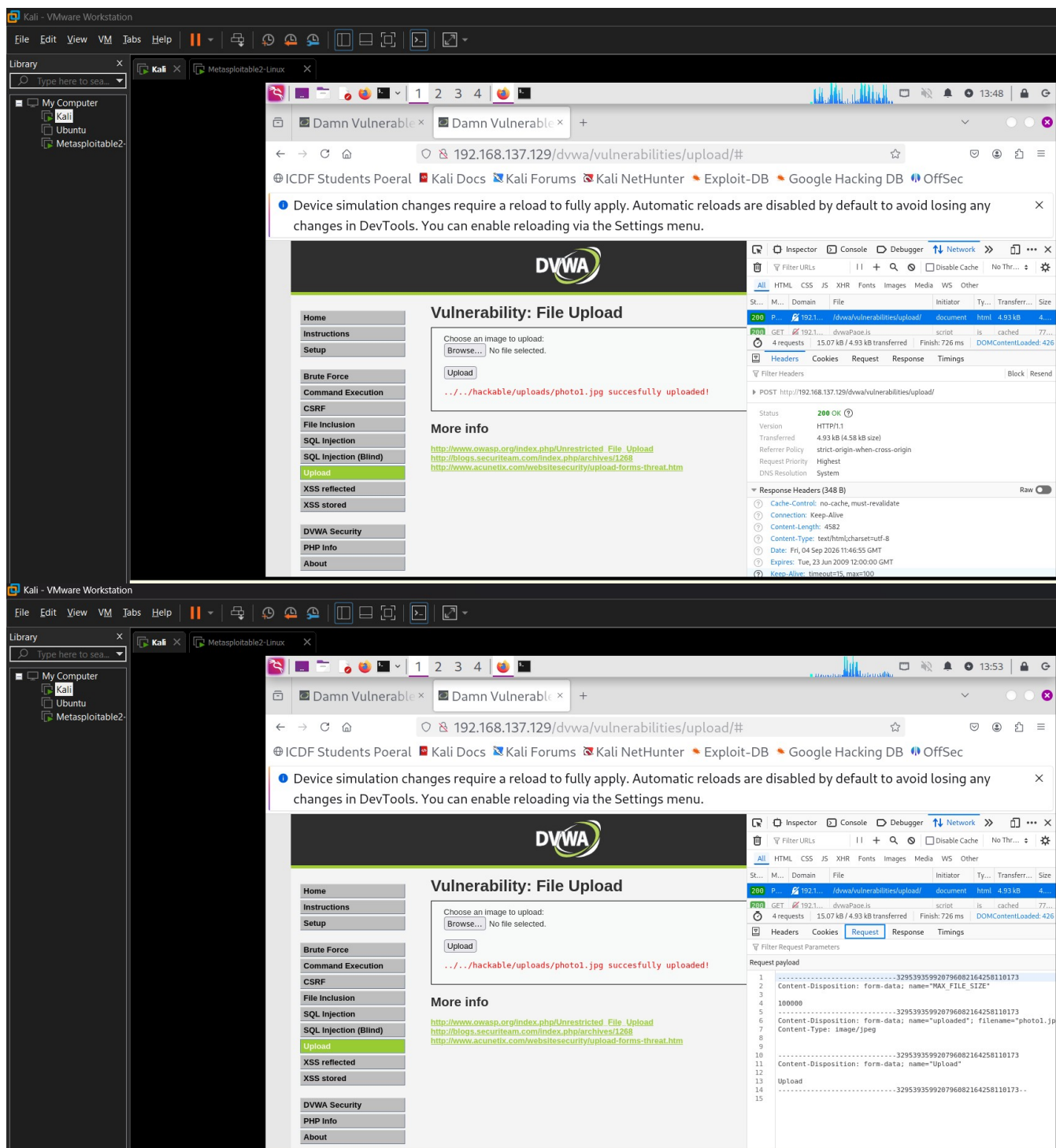


The image above show the result of the page after logged in.

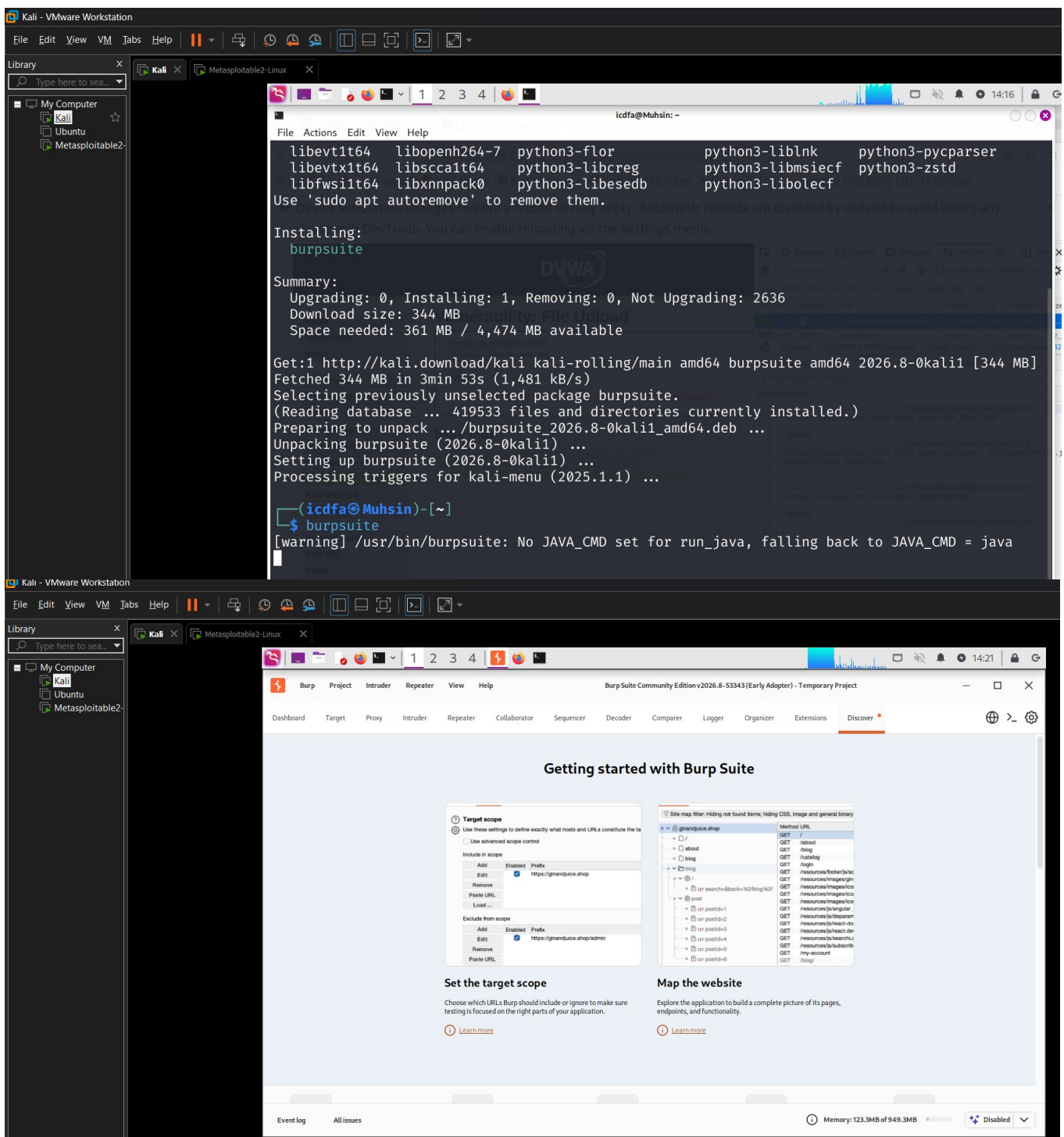


The image above show how the security level was set low.

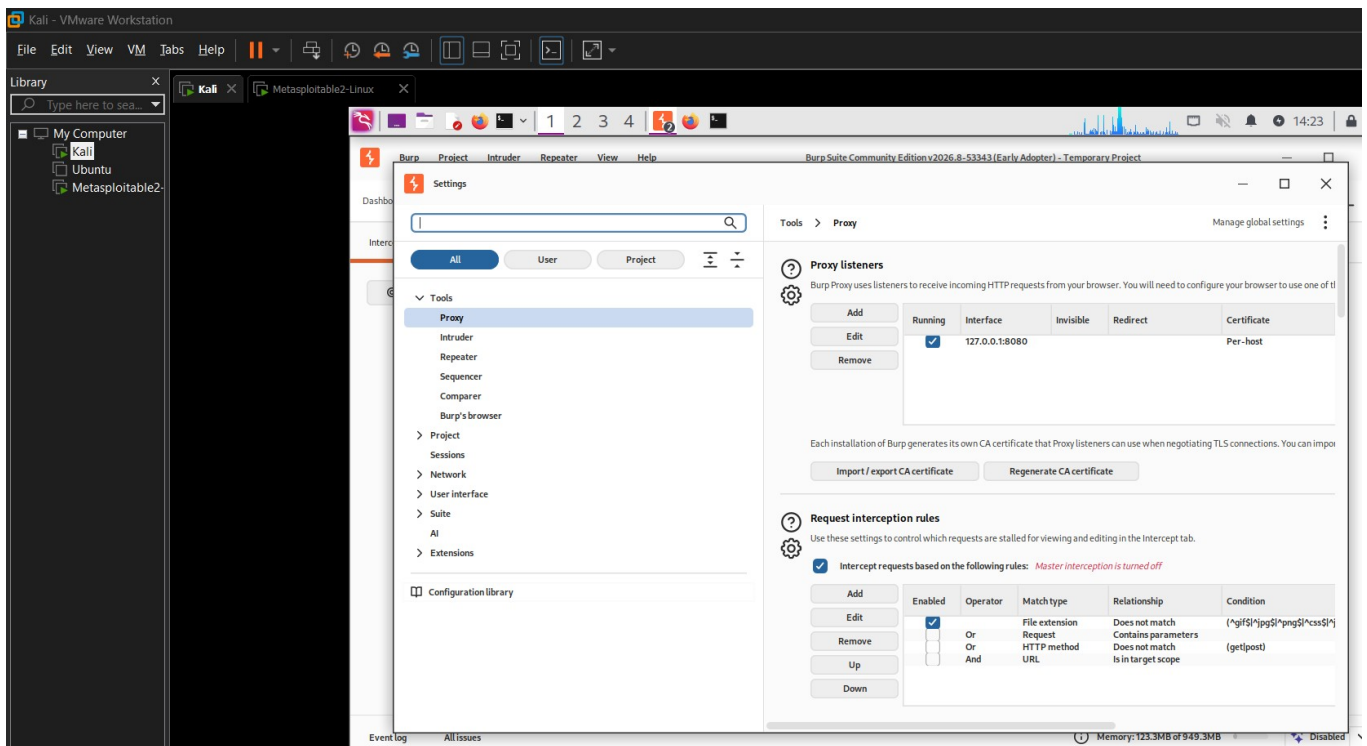




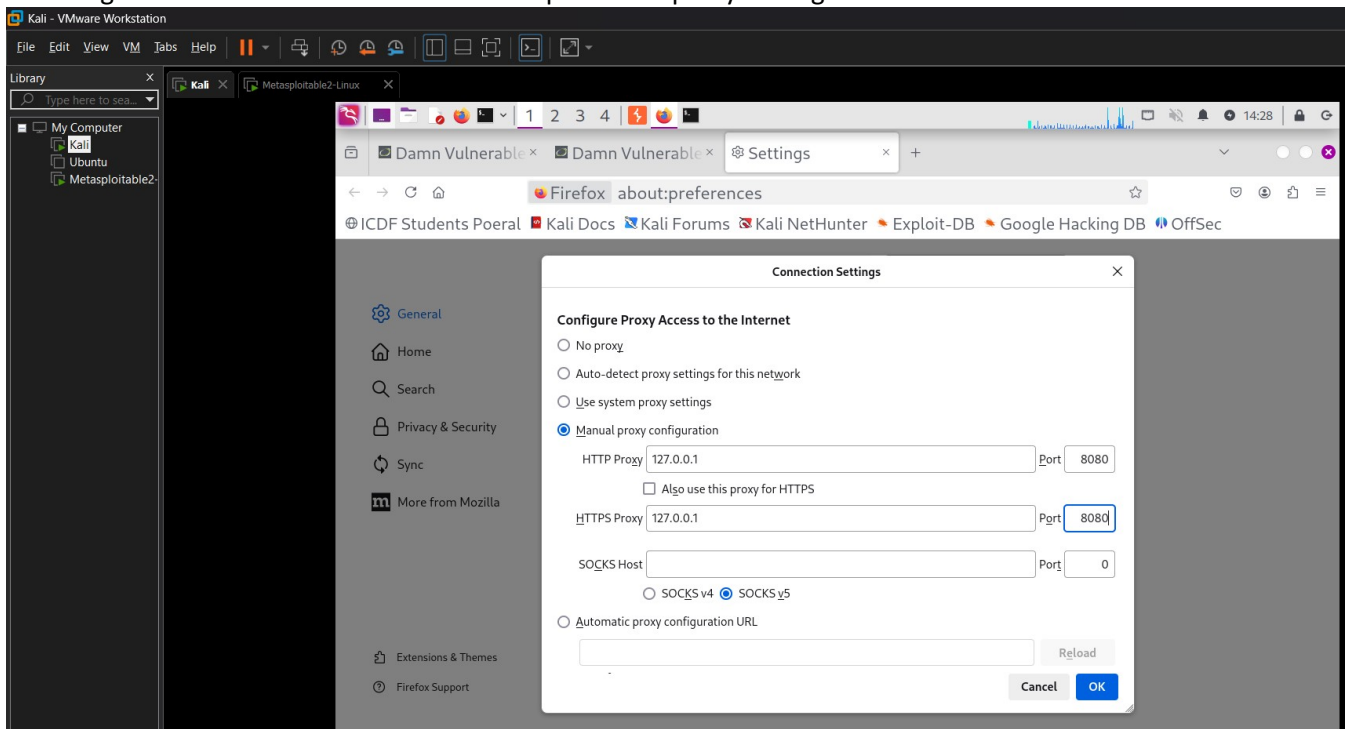
The images above shows the results after i uploaded the .jpg file on the developer tool and I also click on **Post /dvwa/vulnerabilities/upload/**. This shows that the upload file was accepted successfully and also gives useful evidence for the HTTP request inspection.



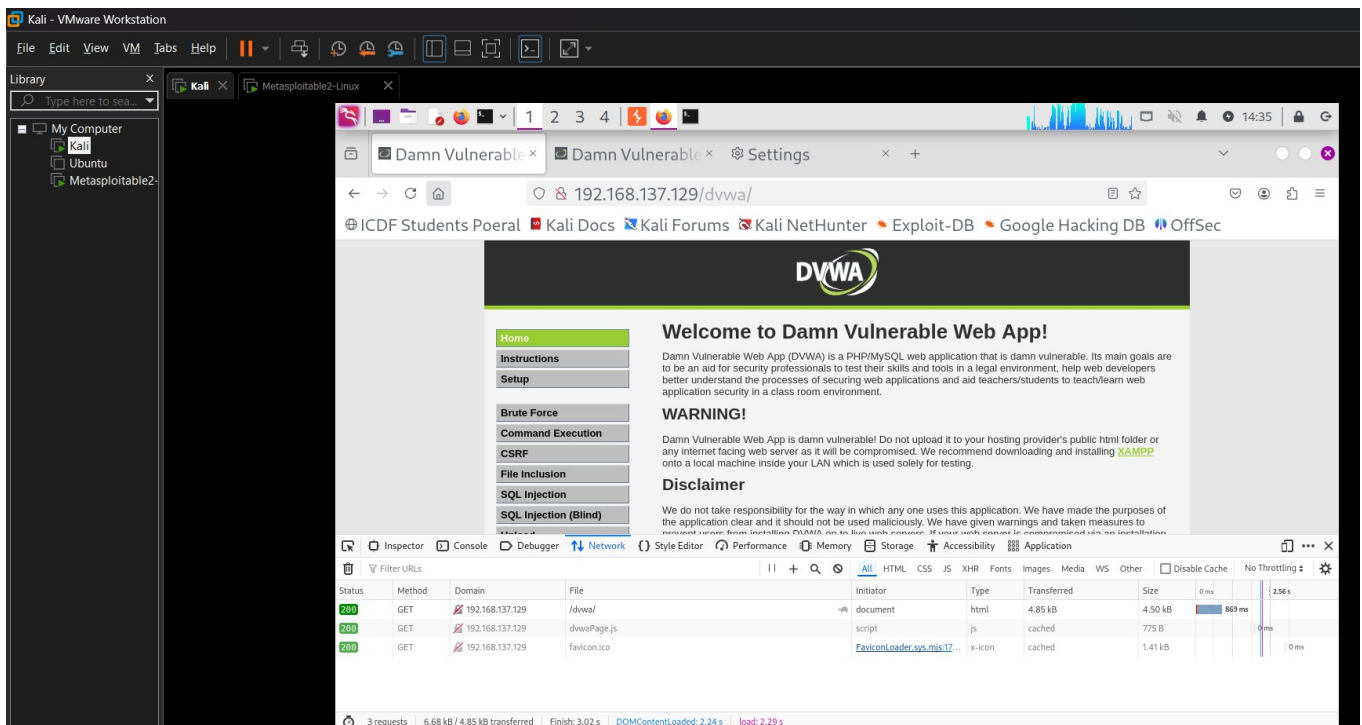
The images above shows the results for **burpsuite running/loading**.



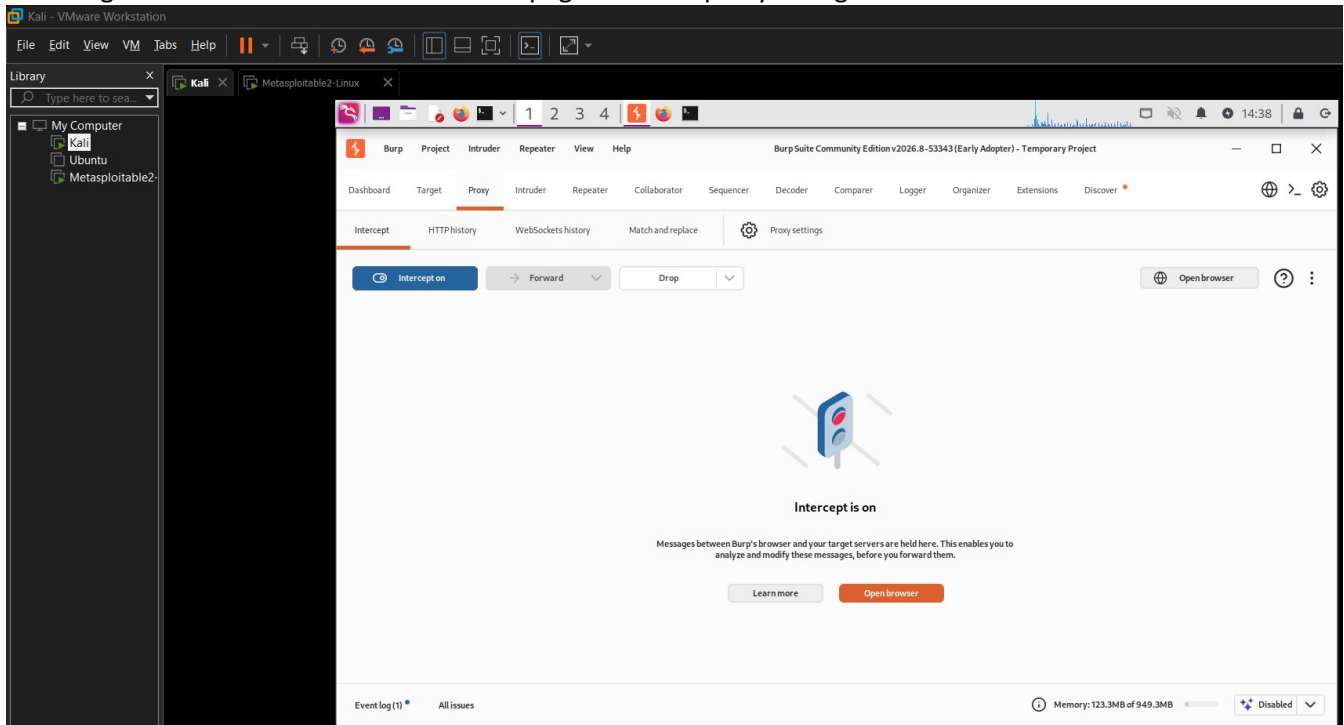
The image above shows the result for the burp browser proxy settings.

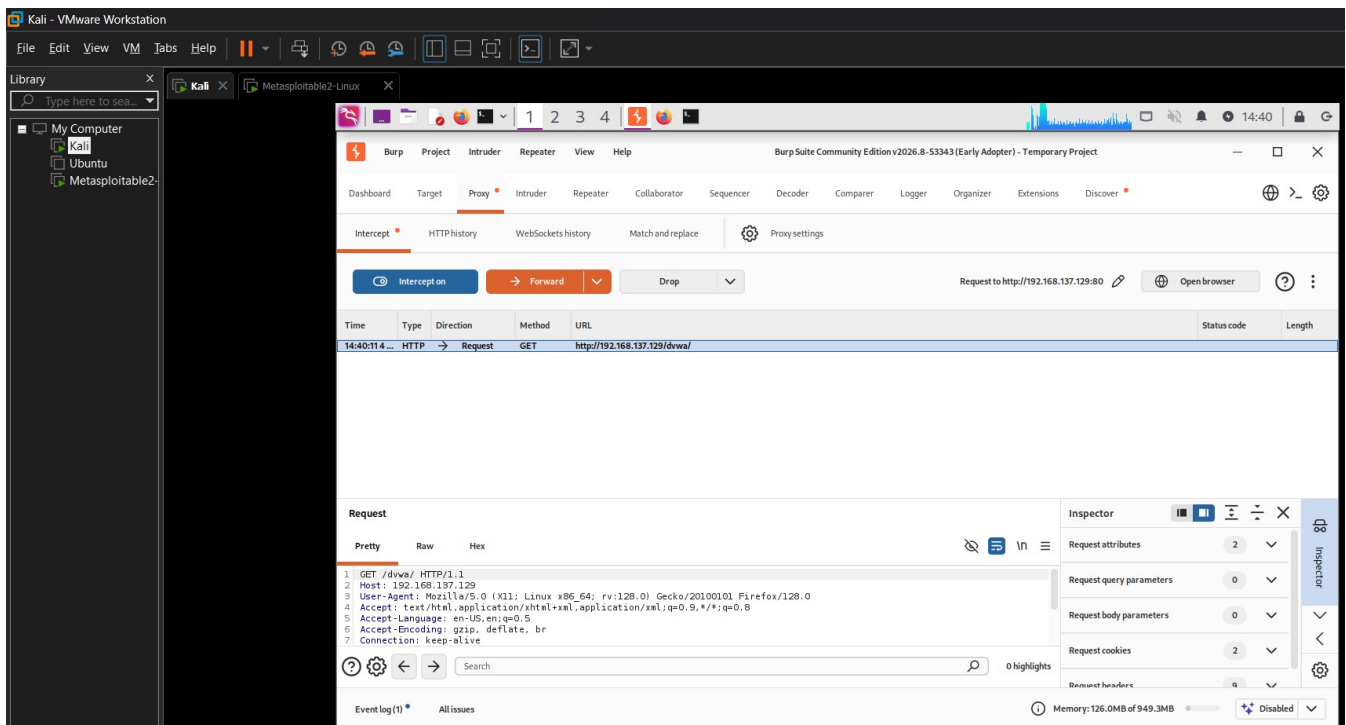


The image above show the result for firefox proxy configuration.

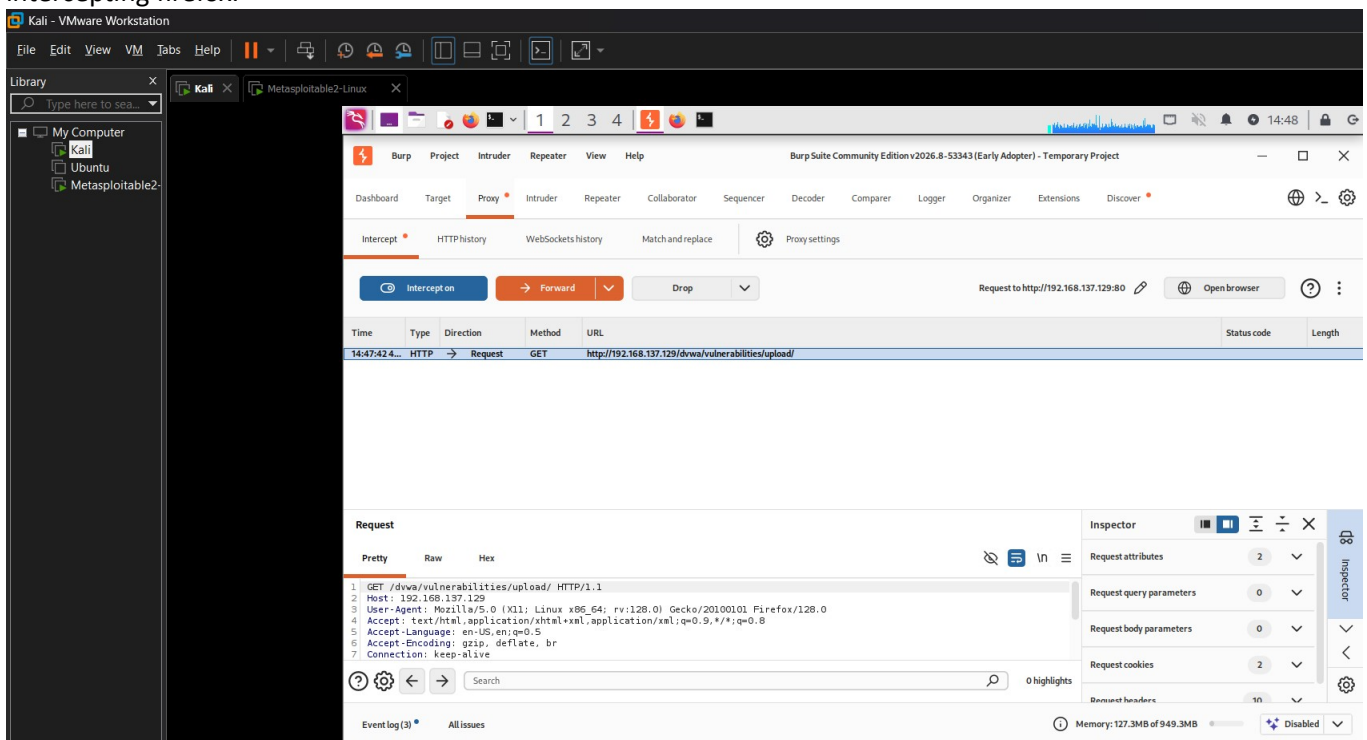


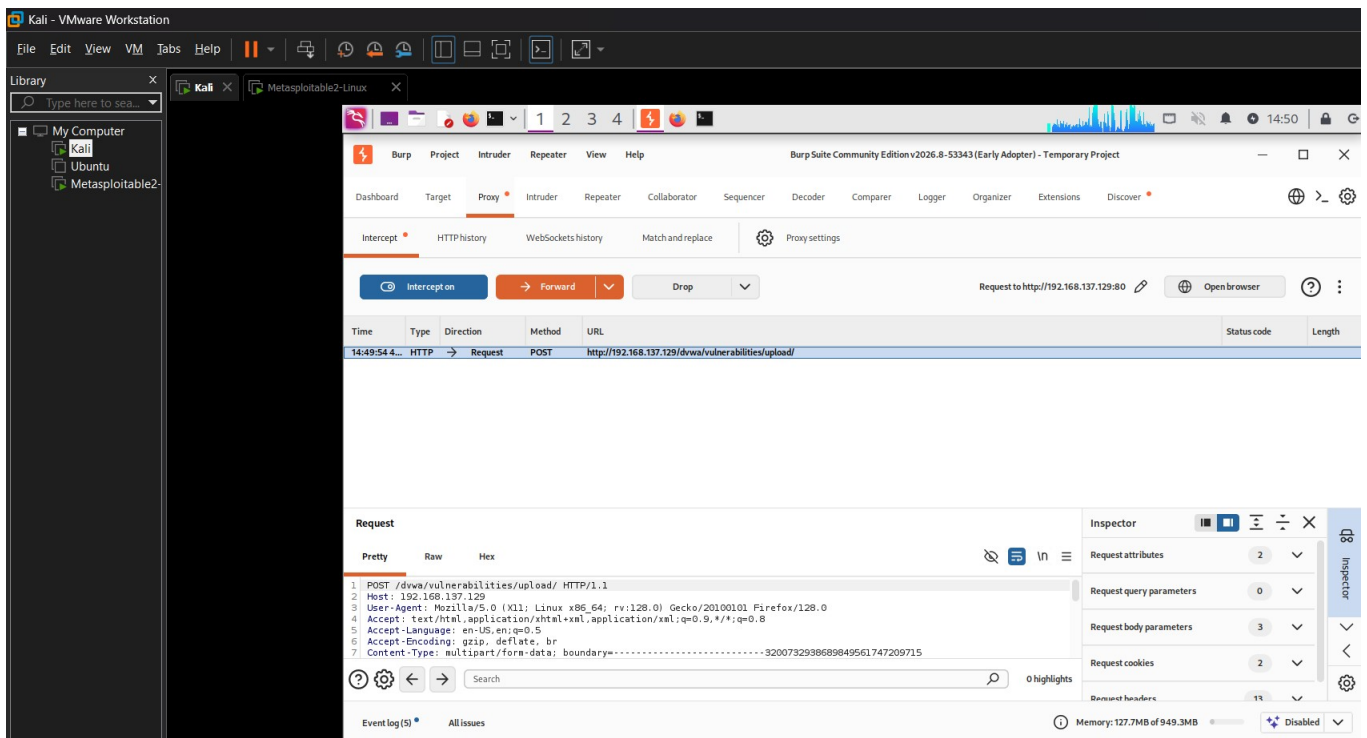
The image above show the result for DVWA page after the proxy configuration.



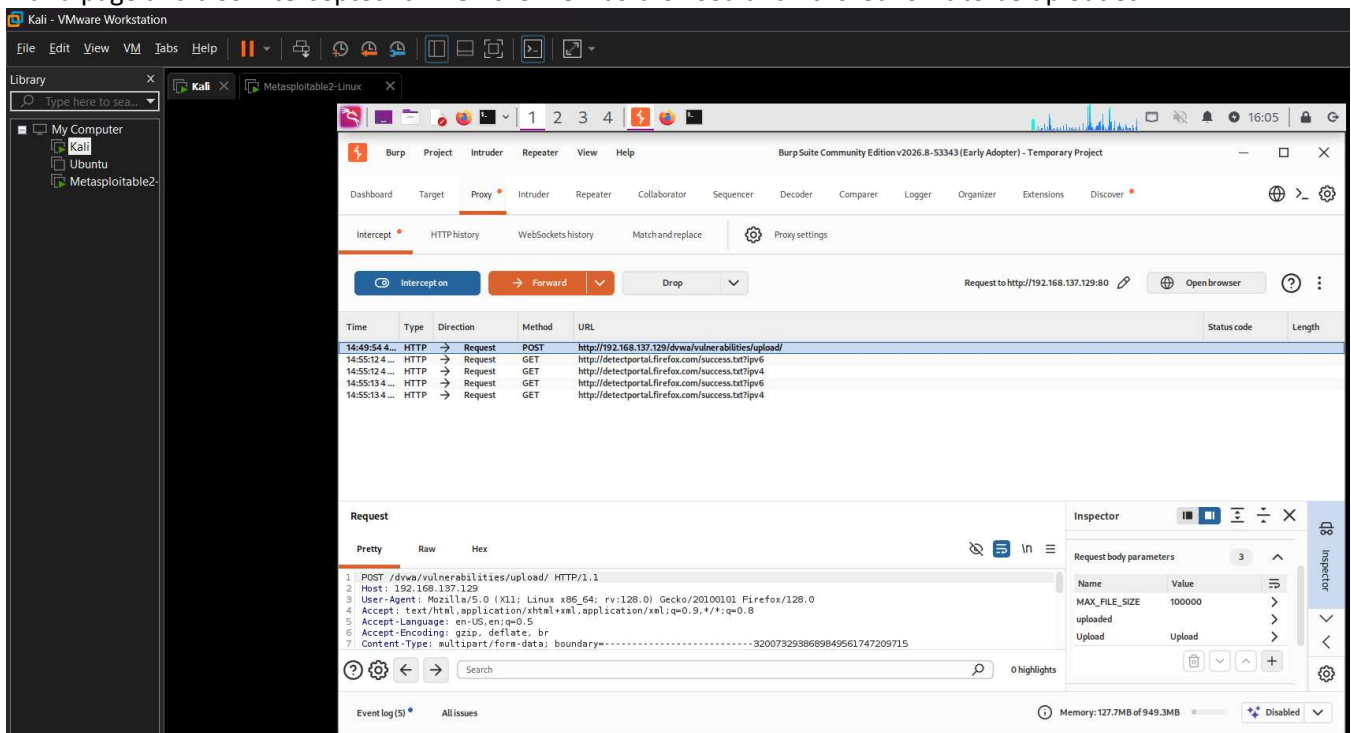


The images above shows the results on how intercept was turned on through burp and the action done on it was intercepting firefox.

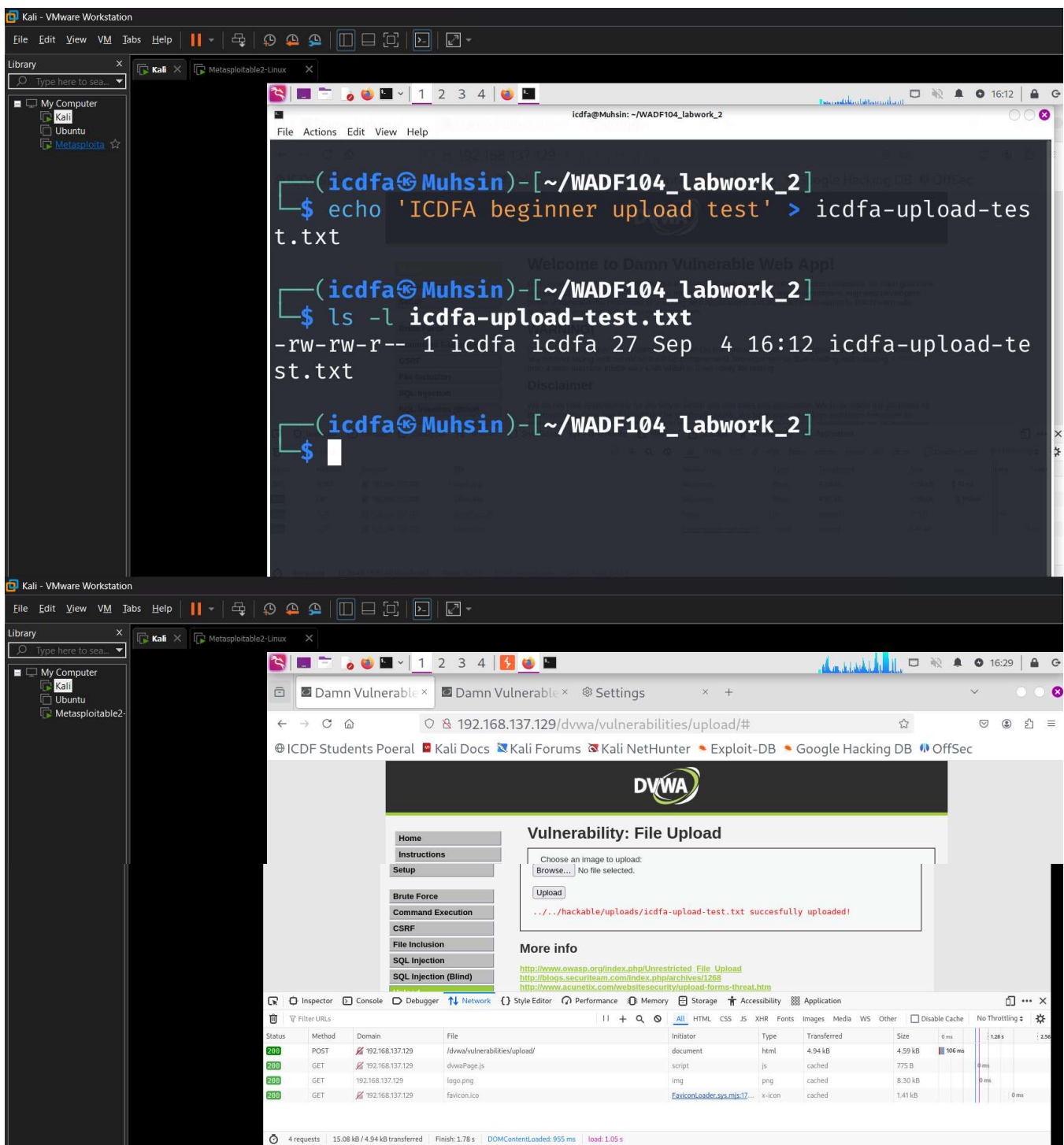




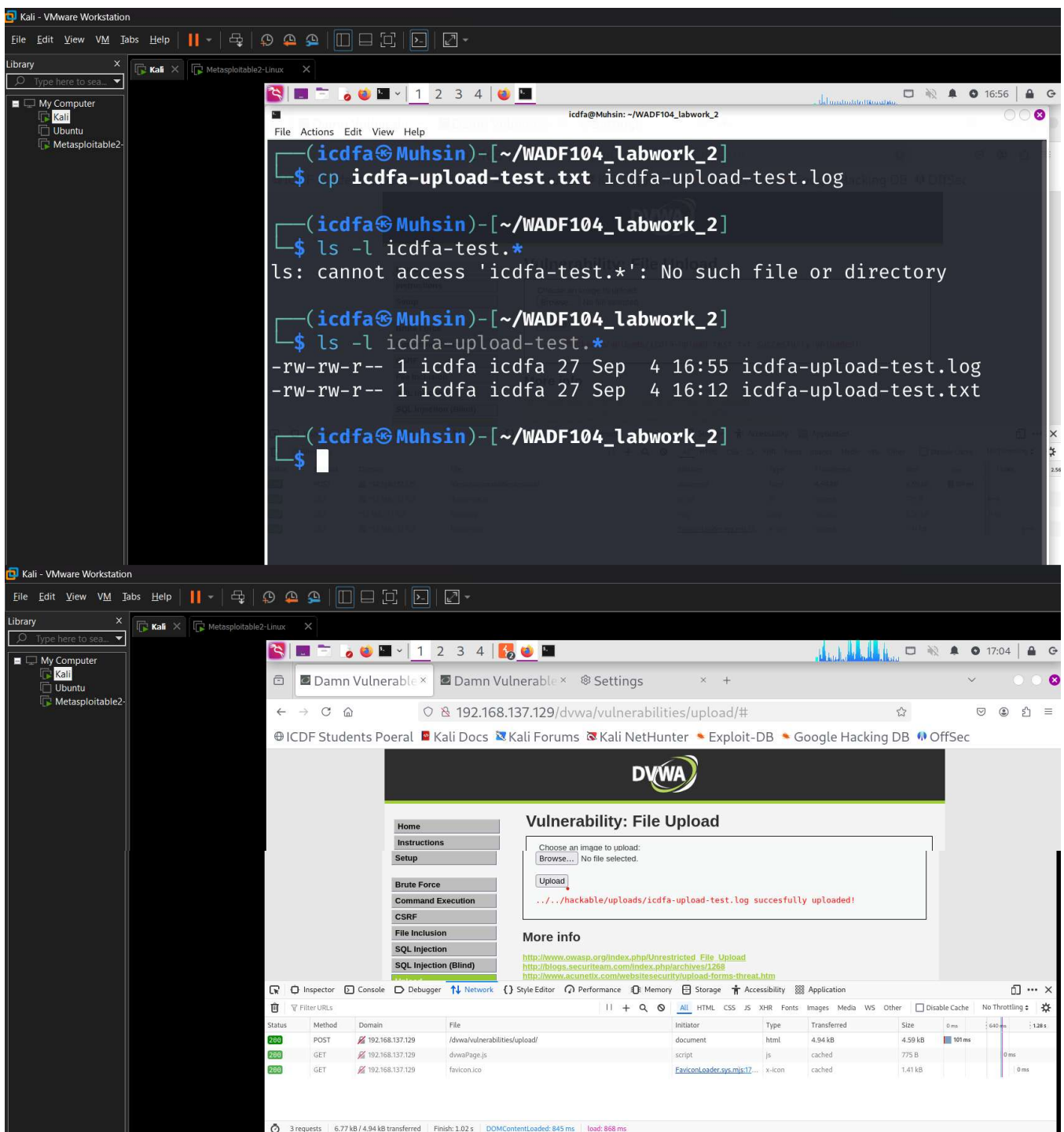
The image above shows how burp captured and intercepted the DMVA page when I clicked upload from the manu page and also intercepted it when the file was browsed and i clicked for it to be uploaded .



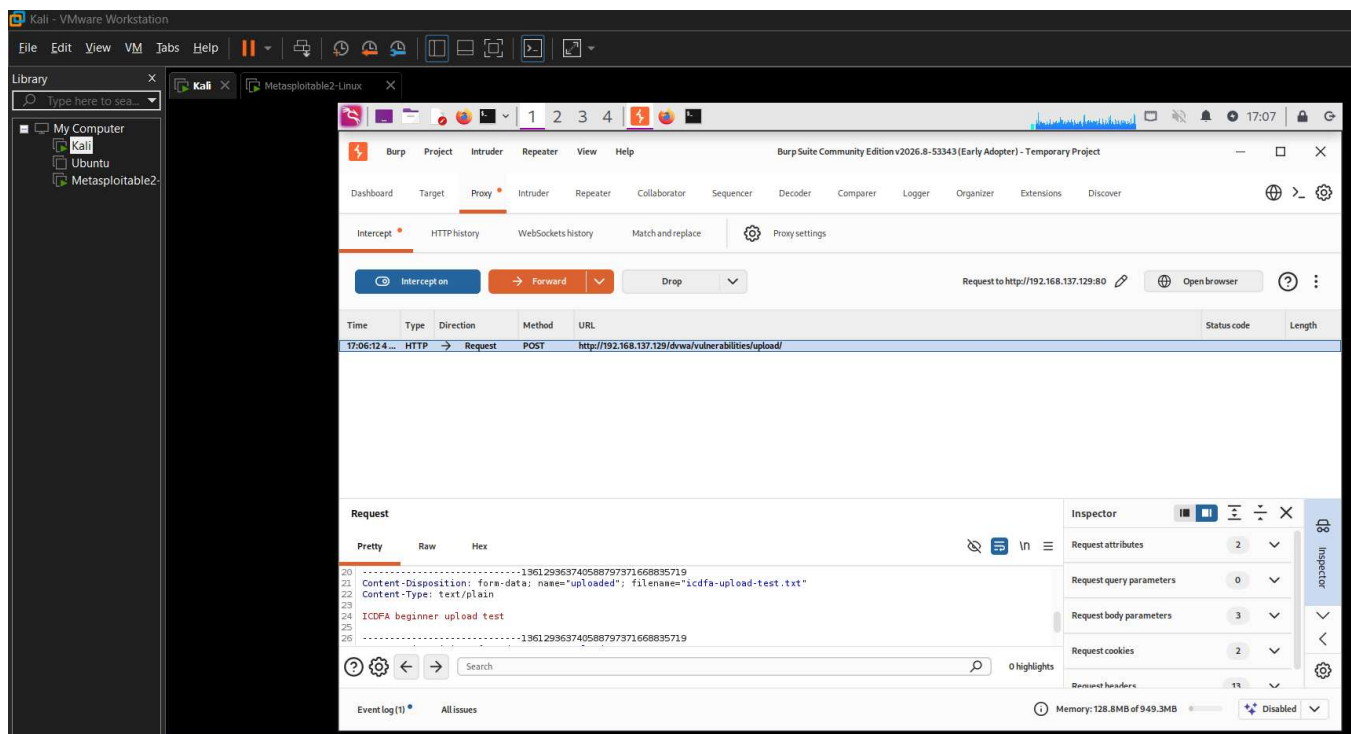
The image above show how Burp can inspect the parameters being submitted in an HTTP file-upload request.



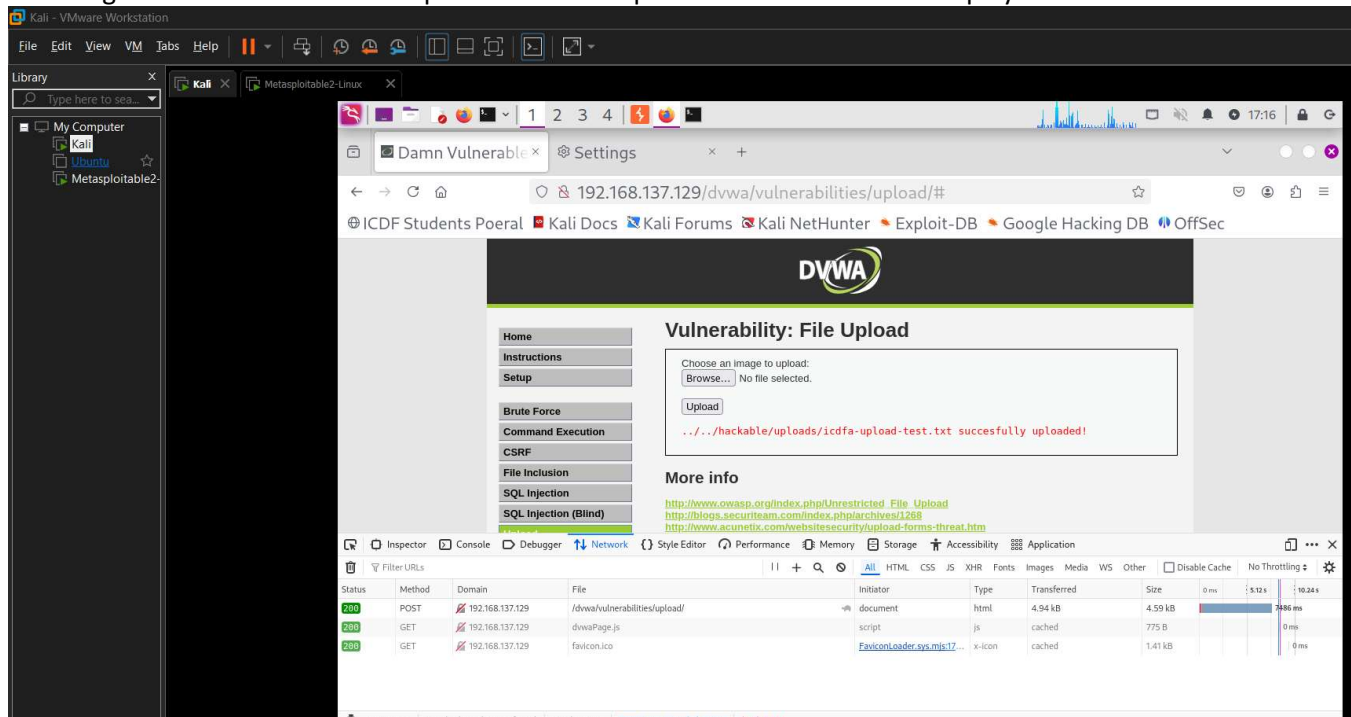
The images above shows the results for `echo 'ICDFA beginner upload test' > icdfa-upload-test.txt` command to create require harmless text file and verified using `ls -l icdfa-upload-test.txt` command. The upload was done on DVWA successfully.



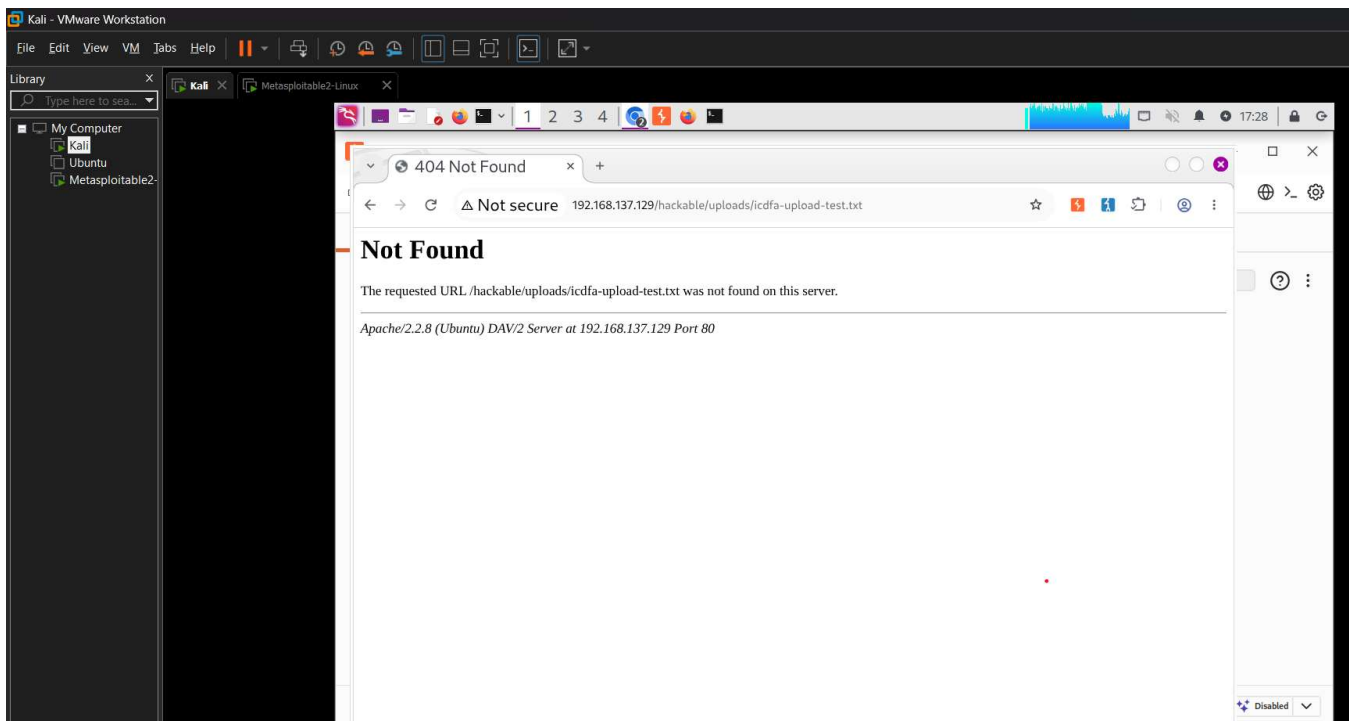
The images above shows the results for `cp icdfa-upload-test.txt icdfa-upload-test.log` command to extend the test to .log and verified by `ls -l icdfa-upload-test.log` comand. The upload of the .log file was uploaded successfully on DVWA.



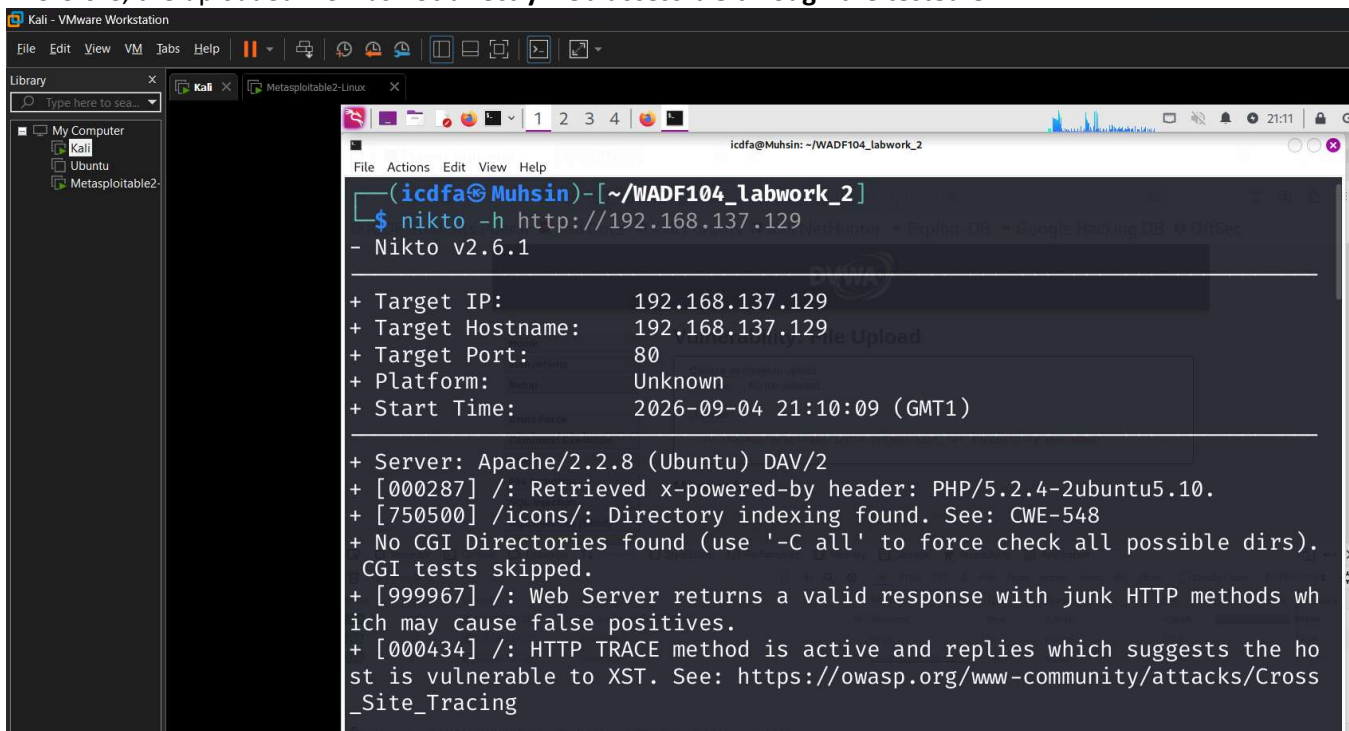
The image above shows how test upload was intercepted and the results was displayed.



The image above show the result of DVWA after the change on request from text/plain to image/png. In this DVWA configuration, changing the MIME type alone **did not prevent the upload**. The application is not relying solely on the MIME type for this validation.



The image above shows the result for storage location/path. The uploaded file was stored under **/hackable/uploads/**, but attempting to access it directly through the web server returned **404 Not Found**. Therefore, the uploaded file was **not directly web-accessible through the tested URL**.



Kali - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADFI04_labwork_2

```
File Actions Edit View Help
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found. See: CWE-548
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://nvd.nist.gov/vuln/detail/CVE-1999-0678
+ [001384] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Eggs reveal potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
```

Kali - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADFI04_labwork_2

```
File Actions Edit View Help
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: https://nvd.nist.gov/vuln/detail/CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found. See: CWE-548
```



```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to sea...
My Computer
Kali
Ubuntu
Metasploit2-Linux
x
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
b.co.uk/apache-restricting-access-to-iconsreadme/
+ [006672] /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL
databases, and should be protected or limited to authorized hosts.
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases,
and should be protected or limited to authorized hosts. See: https://typo3.
org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with th
e Content-Security-Policy HTTP header with the frame-ancestors directive. S
ee: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-F
rame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allo
w the user agent to render the content of the site in a different fashion t
o the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/
vulnerabilities/missing-content-type-header/
+ 8236 requests: 1 error and 31 items reported on the remote host
+ End Time: 2026-09-04 21:11:13 (GMT1) (64 seconds)

+ 1 host(s) tested

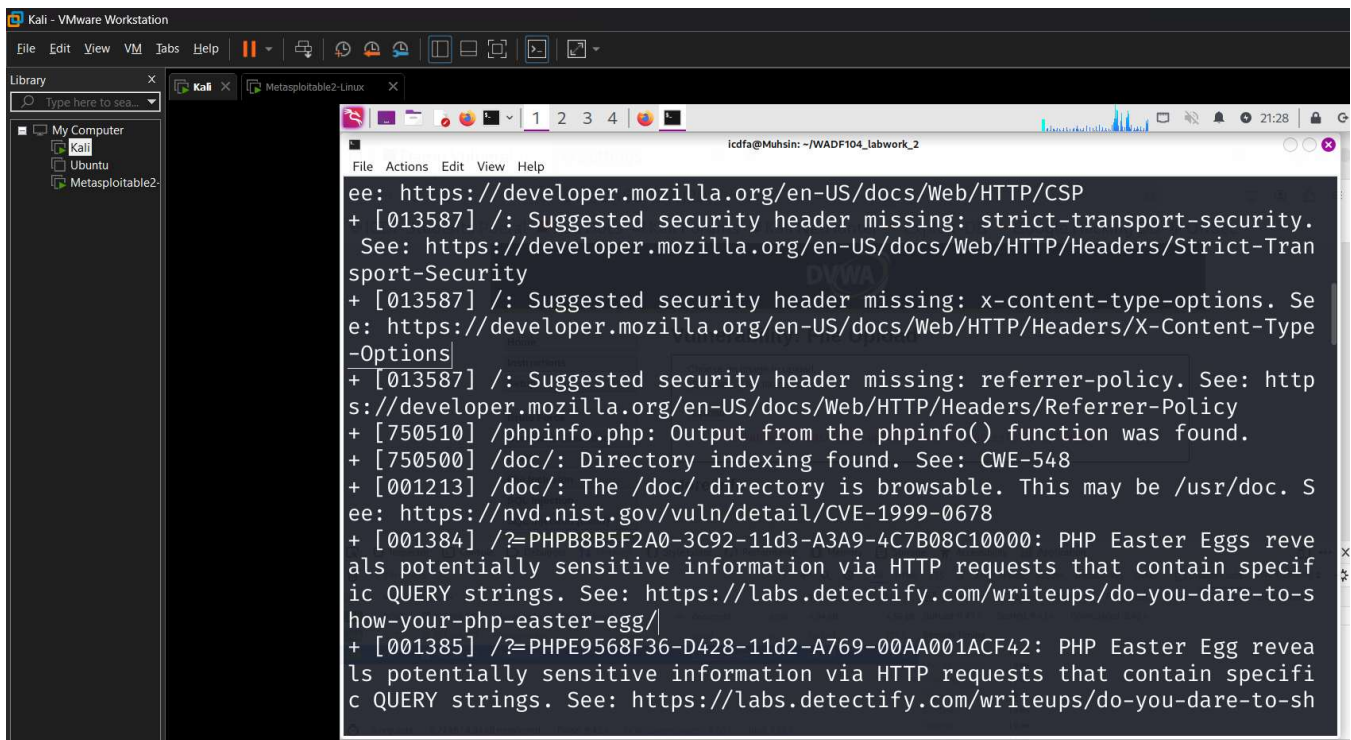
(icdfa@Muhsin)-[~/WADF104_labwork_2]
```

The images above shows the results for **nikto -h http://192.168.137.129** command which successfully scan the lab target.

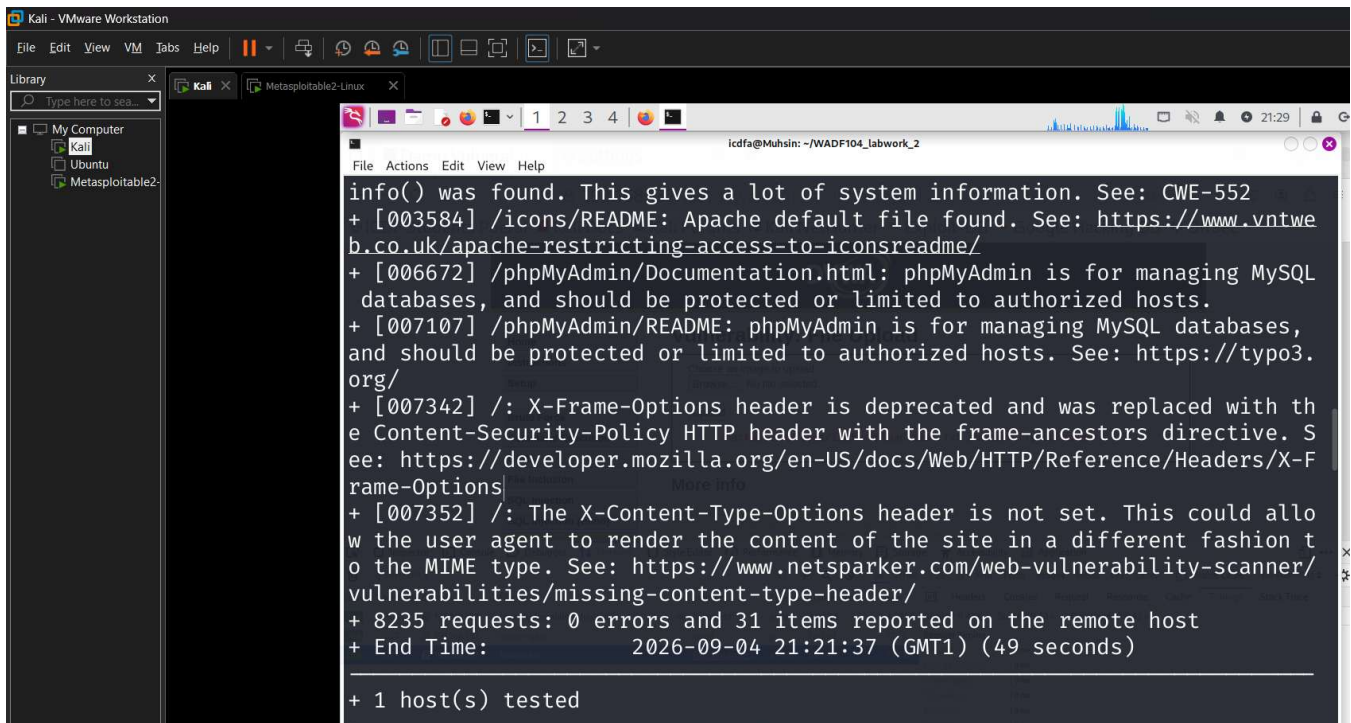
```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to sea...
My Computer
Kali
Ubuntu
Metasploit2-Linux
x
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$ nikto -h http://192.168.137.129 -output nikto-results.txt
- Nikto v2.6.1

+ Target IP: 192.168.137.129
+ Target Hostname: 192.168.137.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-04 21:20:48 (GMT1)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [000287] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found. See: CWE-548
+ No CGI Directories found (use '-C all' to force check all possible dirs).
CGI tests skipped.
+ [999967] /: Web Server returns a valid response with junk HTTP methods wh
ich may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the ho
st is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross
```

```
ee: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security.
  See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found. See: CWE-548
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://nvd.nist.gov/vuln/detail/CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveal potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-sh
```



```
info() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006672] /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8235 requests: 0 errors and 31 items reported on the remote host
+ End Time: 2026-09-04 21:21:37 (GMT1) (49 seconds)

+ 1 host(s) tested
```

The images above shows the results for **nikto -h http://192.168.137.129 -output nikto-results.txt** command. It saved the complete output.

Kali - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADF104_labwork_2

```
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$ cat nikto-results.txt
- Nikto v2.6.1/
+ Target Host: 192.168.137.129
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found. See: CWE-548:
+ CFQHLCUV /: Web Server returns a valid response with junk HTTP methods wh
ich may cause false positives.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host
is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Si
te_Tracing:
+ GET /index: Uncommon header(s) 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allo
ws attackers to easily brute force file names. The following alternatives f
or 'index' were found: index.php. See: https://exchange.xforce.ibmcloud.com
/vulnerabilities/8275:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least 2.4.68).
+ HEAD PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.
5.8).
```

Kali - VMware Workstation

File Edit View VM Tabs Help

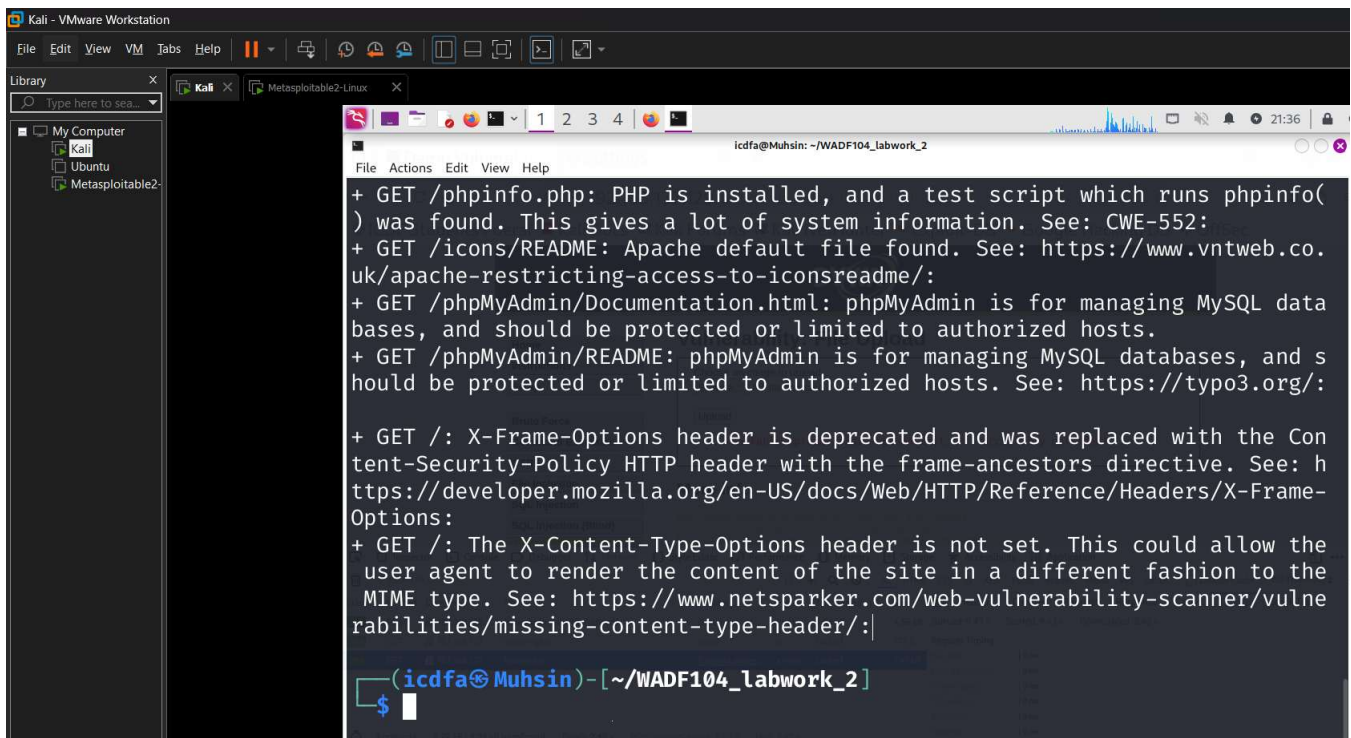
Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADF104_labwork_2

```
+ GET /: Suggested security header missing: permissions-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: content-security-policy. See: h
ttps://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: strict-transport-security. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport
-Security:
+ GET /: Suggested security header missing: x-content-type-options. See: 'nt
tps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opti
ons:
+ GET /: Suggested security header missing: referrer-policy. See: https://d
eveloper.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found. See: CWE-548:
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: C
VE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals p
otentially sensitive information via HTTP requests that contain specific QU
ERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-y
our-php-easter-egg/:
```



```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo(
) was found. This gives a lot of system information. See: CWE-552:
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.
uk/apache-restricting-access-to-iconsreadme/:
+ GET /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL data
bases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and s
hould be protected or limited to authorized hosts. See: https://typo3.org/:
+ GET /: X-Frame-Options header is deprecated and was replaced with the Con
tent-Security-Policy HTTP header with the frame-ancestors directive. See: h
ttps://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-
Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the
user agent to render the content of the site in a different fashion to the
MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulne
rabilities/missing-content-type-header/:|
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$
```

The images above shows the results for **cat nikto-results.txt** command.

The five findings are:

No	Nkito finding	What it indicates
1	PHP/5.2.4-2ubuntu5.10 appears outdated	Old PHP version may contain known security vulnerabilities.
2	Apache/2.2.8 appears outdated	Old web-server version may contain known vulnerabilities.
3.	Directory indexing found at /icons/	Users may be able to browse files/directories that should not be exposed.
4.	HTTP TRACE method is active	TRACE can contribute to Cross-Site Tracing (XST) attacks
5.	Apache MultiViews enabled	Can make it easier to discover alternative filenames/resources through content negotiation.


```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploit2-Linux
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
+ http://192.168.137.129/phpMyAdmin/changelog (CODE:200|SIZE:74593)
+ http://192.168.137.129/phpMyAdmin/ChangeLog (CODE:200|SIZE:40540)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/contrib/
+ http://192.168.137.129/phpMyAdmin/docs (CODE:200|SIZE:4583)
+ http://192.168.137.129/phpMyAdmin/error (CODE:200|SIZE:1063)
+ http://192.168.137.129/phpMyAdmin/export (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)
+ http://192.168.137.129/phpMyAdmin/import (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/index (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/index.php (CODE:200|SIZE:4145)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/js/

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/lang/

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/libraries/
+ http://192.168.137.129/phpMyAdmin/license (CODE:200|SIZE:18011)
+ http://192.168.137.129/phpMyAdmin/LICENSE (CODE:200|SIZE:18011)
+ http://192.168.137.129/phpMyAdmin/main (CODE:200|SIZE:4227)
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploit2-Linux
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
+ http://192.168.137.129/phpMyAdmin/phpinfo (CODE:200|SIZE:0)
+ http://192.168.137.129/phpMyAdmin/phpinfo.php (CODE:200|SIZE:0)
+ http://192.168.137.129/phpMyAdmin/phpmyadmin (CODE:200|SIZE:21389)
+ http://192.168.137.129/phpMyAdmin/print (CODE:200|SIZE:1063)
+ http://192.168.137.129/phpMyAdmin/readme (CODE:200|SIZE:2624)
+ http://192.168.137.129/phpMyAdmin/README (CODE:200|SIZE:2624)
+ http://192.168.137.129/phpMyAdmin/robots (CODE:200|SIZE:26)
+ http://192.168.137.129/phpMyAdmin/robots.txt (CODE:200|SIZE:26)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/scripts/

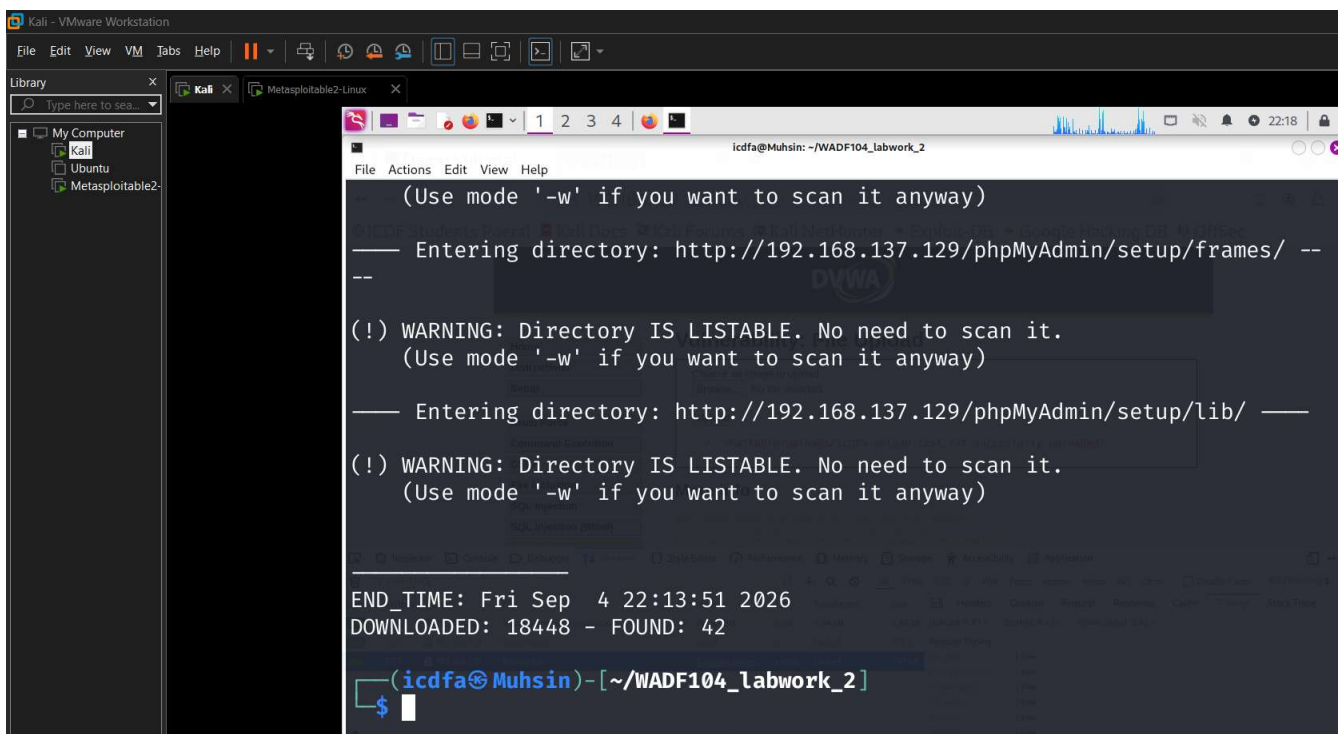
=> DIRECTORY: http://192.168.137.129/phpMyAdmin/setup/
+ http://192.168.137.129/phpMyAdmin/sql (CODE:200|SIZE:4145)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/test/

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/themes/
+ http://192.168.137.129/phpMyAdmin/TODO (CODE:200|SIZE:235)
+ http://192.168.137.129/phpMyAdmin/webapp (CODE:200|SIZE:6903)
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to search
My Computer
Kali
Ubuntu
Metasploit2
Metasploit2-Linux
icdf@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/twiki/ —
⇒ DIRECTORY: http://192.168.137.129/twiki/bin/
+ http://192.168.137.129/twiki/data (CODE:403|SIZE:298)
+ http://192.168.137.129/twiki/index (CODE:200|SIZE:782)
+ http://192.168.137.129/twiki/index.html (CODE:200|SIZE:782)
⇒ DIRECTORY: http://192.168.137.129/twiki/lib/
+ http://192.168.137.129/twiki/license (CODE:200|SIZE:19440)
⇒ DIRECTORY: http://192.168.137.129/twiki/pub/
+ http://192.168.137.129/twiki/readme (CODE:200|SIZE:4334)
+ http://192.168.137.129/twiki/templates (CODE:403|SIZE:303)
— Entering directory: http://192.168.137.129/phpMyAdmin/contrib/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to search
My Computer
Kali
Ubuntu
Metasploit2
Metasploit2-Linux
icdf@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
— Entering directory: http://192.168.137.129/phpMyAdmin/themes/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/twiki/bin/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/twiki/lib/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/twiki/pub/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```



```
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.137.129/phpMyAdmin/setup/frames/ --
--

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.137.129/phpMyAdmin/setup/lib/ —

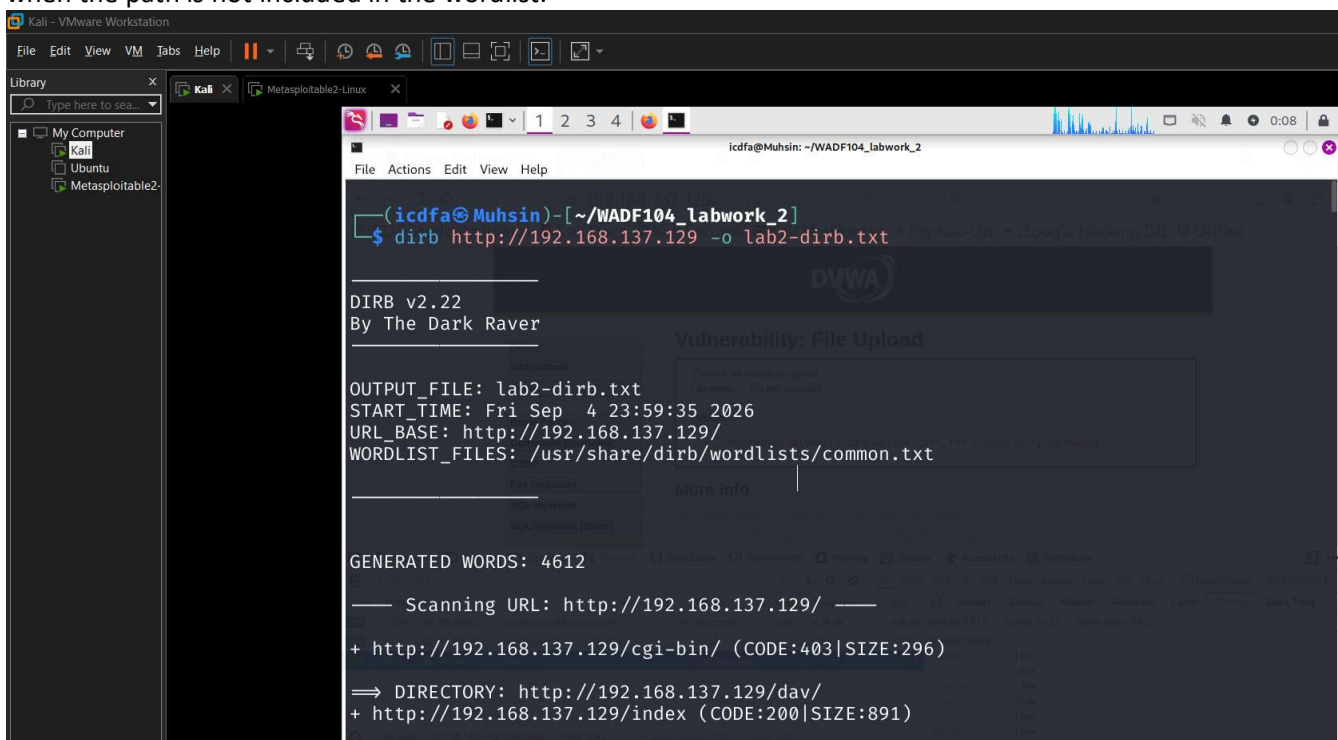
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Fri Sep 4 22:13:51 2026
DOWNLOADED: 18448 - FOUND: 42

(icdfa@Muhsin)-[~/WADF104_labwork_2]
$
```

The images above shows the results for **dirb http://192.168.137.129** command. The **DIRB** scan successfully identified several unlinked or predictable directories and resources on the authorised web server. The scan returned 42 discovered paths, demonstrating that content discovery can reveal additional web application resources that may not be directly linked from the main page.

Relate DIRB to Uploads: Based on the step 17 above: DIRB identified several accessible directories and files on the target web server, including **/phpMyAdmin/**, **/phpMyAdmin/test/**, and **/test/**. However, the DIRB results did not directly identify the **/hackable/uploads/** directory used by the DVWA File Upload functionality. This demonstrates that directory enumeration tools may not discover every application-specific path, particularly when the path is not included in the wordlist.



```
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$ dirb http://192.168.137.129 -o lab2-dirb.txt

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: lab2-dirb.txt
START_TIME: Fri Sep 4 23:59:35 2026
URL_BASE: http://192.168.137.129/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://192.168.137.129/ —

+ http://192.168.137.129/cgi-bin/ (CODE:403|SIZE:296)
=> DIRECTORY: http://192.168.137.129/dav/
+ http://192.168.137.129/index (CODE:200|SIZE:891)
```


Kali - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADF104_labwork_2

```
File Actions Edit View Help
+ http://192.168.137.129/phpinfo (CODE:200|SIZE:48101)
+ http://192.168.137.129/phpinfo.php (CODE:200|SIZE:48113)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/
+ http://192.168.137.129/server-status (CODE:403|SIZE:301)

=> DIRECTORY: http://192.168.137.129/test/
=> DIRECTORY: http://192.168.137.129/twiki/

— Entering directory: http://192.168.137.129/dav/ —

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.137.129/phpMyAdmin/ —

+ http://192.168.137.129/phpMyAdmin/calendar (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/changelog (CODE:200|SIZE:74593)
+ http://192.168.137.129/phpMyAdmin/ChangeLog (CODE:200|SIZE:40540)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/contrib/
+ http://192.168.137.129/phpMyAdmin/docs (CODE:200|SIZE:4583)
+ http://192.168.137.129/phpMyAdmin/error (CODE:200|SIZE:1063)
+ http://192.168.137.129/phpMyAdmin/export (CODE:200|SIZE:4145)
```

Kali - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Kali
- Ubuntu
- Metasploitable2

icdfa@Muhsin: ~/WADF104_labwork_2

```
File Actions Edit View Help

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/contrib/
+ http://192.168.137.129/phpMyAdmin/docs (CODE:200|SIZE:4583)
+ http://192.168.137.129/phpMyAdmin/error (CODE:200|SIZE:1063)
+ http://192.168.137.129/phpMyAdmin/export (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)
+ http://192.168.137.129/phpMyAdmin/import (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/index (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/index.php (CODE:200|SIZE:4145)

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/js/

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/lang/

=> DIRECTORY: http://192.168.137.129/phpMyAdmin/libraries/
+ http://192.168.137.129/phpMyAdmin/license (CODE:200|SIZE:18011)
+ http://192.168.137.129/phpMyAdmin/LICENSE (CODE:200|SIZE:18011)
+ http://192.168.137.129/phpMyAdmin/main (CODE:200|SIZE:4227)
+ http://192.168.137.129/phpMyAdmin/navigation (CODE:200|SIZE:4145)
+ http://192.168.137.129/phpMyAdmin/phpinfo (CODE:200|SIZE:0)
+ http://192.168.137.129/phpMyAdmin/phpmyadmin (CODE:200|SIZE:21389)
+ http://192.168.137.129/phpMyAdmin/print (CODE:200|SIZE:1063)
+ http://192.168.137.129/phpMyAdmin/readme (CODE:200|SIZE:2624)
+ http://192.168.137.129/phpMyAdmin/README (CODE:200|SIZE:2624)
```

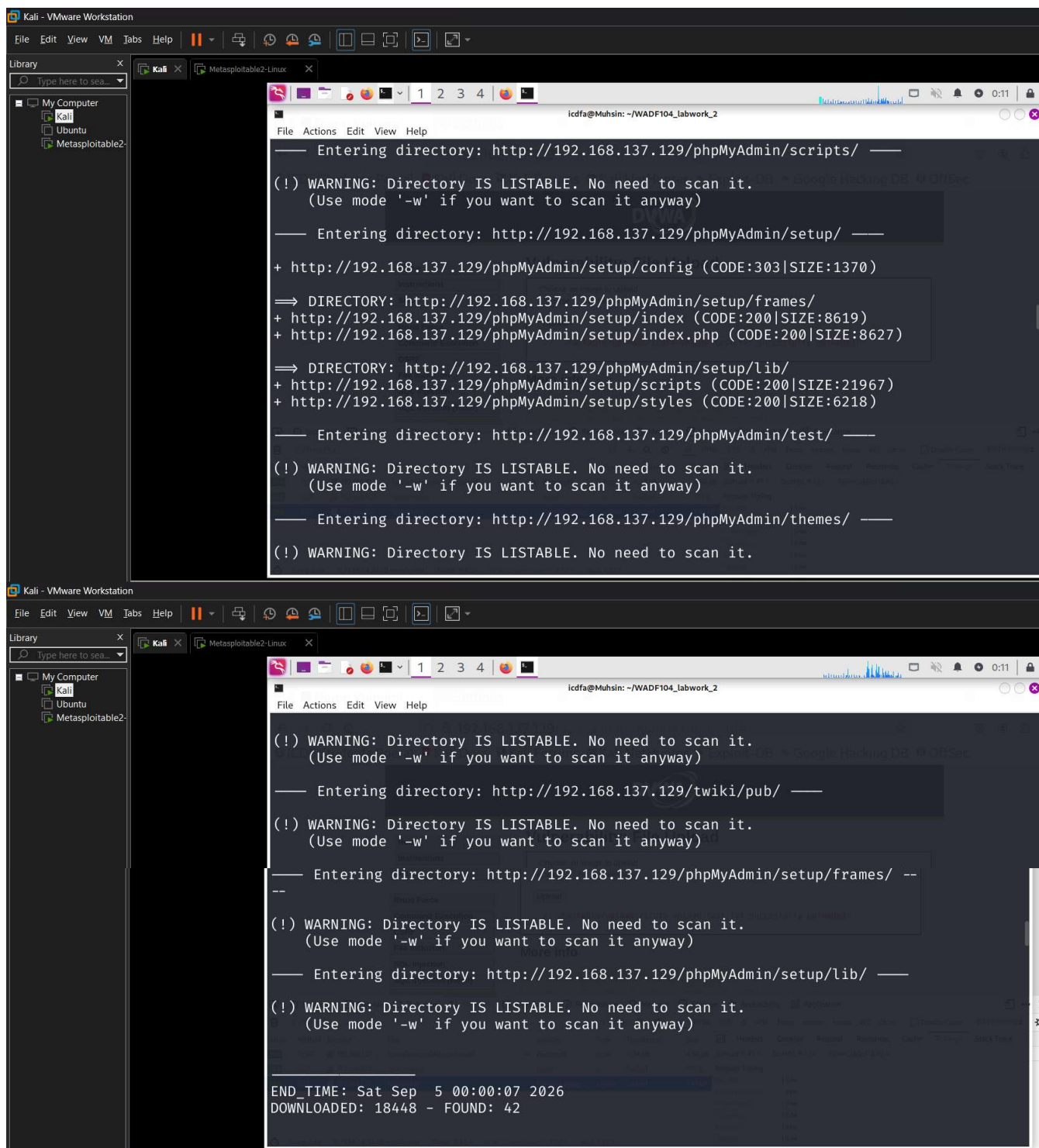


```
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2

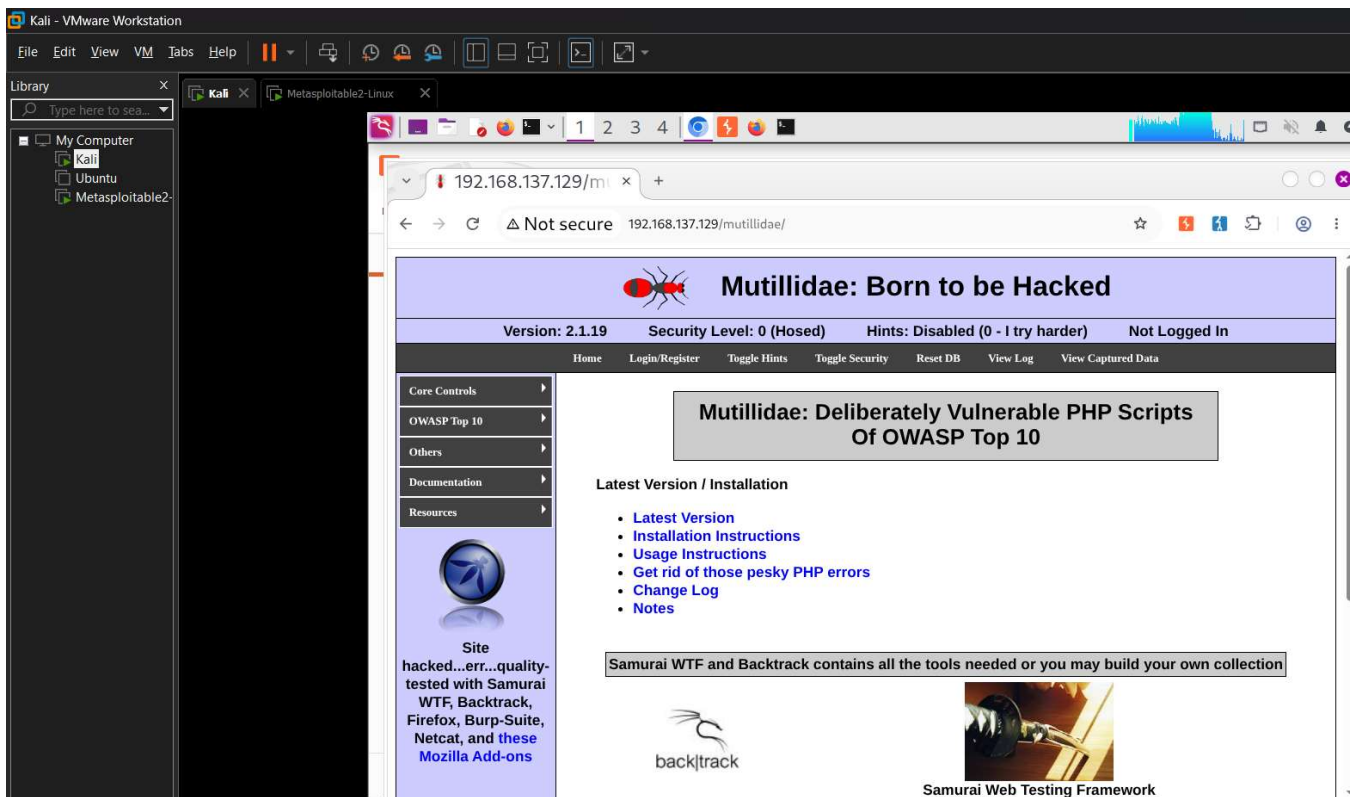
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
+ http://192.168.137.129/phpMyAdmin/robots (CODE:200|SIZE:26)
+ http://192.168.137.129/phpMyAdmin/robots.txt (CODE:200|SIZE:26)
=> DIRECTORY: http://192.168.137.129/phpMyAdmin/scripts/
=> DIRECTORY: http://192.168.137.129/phpMyAdmin/setup/
+ http://192.168.137.129/phpMyAdmin/sql (CODE:200|SIZE:4145)
=> DIRECTORY: http://192.168.137.129/phpMyAdmin/test/
=> DIRECTORY: http://192.168.137.129/phpMyAdmin/themes/
+ http://192.168.137.129/phpMyAdmin/TOD0 (CODE:200|SIZE:235)
+ http://192.168.137.129/phpMyAdmin/webapp (CODE:200|SIZE:6903)
— Entering directory: http://192.168.137.129/test/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/twiki/ —
=> DIRECTORY: http://192.168.137.129/twiki/bin/
+ http://192.168.137.129/twiki/data (CODE:403|SIZE:298)
+ http://192.168.137.129/twiki/index (CODE:200|SIZE:782)
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2

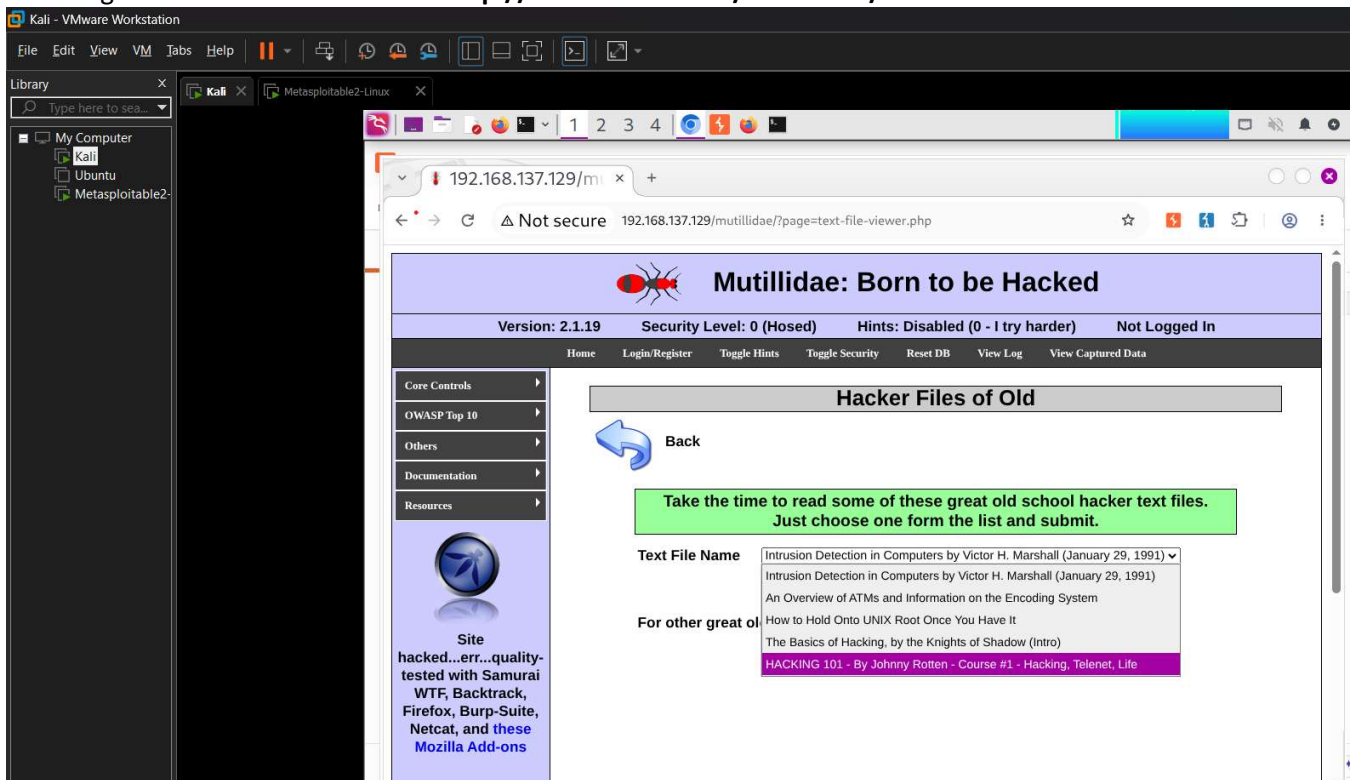
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
=> DIRECTORY: http://192.168.137.129/twiki/lib/
+ http://192.168.137.129/twiki/license (CODE:200|SIZE:19440)
=> DIRECTORY: http://192.168.137.129/twiki/pub/
+ http://192.168.137.129/twiki/readme (CODE:200|SIZE:4334)
+ http://192.168.137.129/twiki/templates (CODE:403|SIZE:303)
— Entering directory: http://192.168.137.129/phpMyAdmin/contrib/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/phpMyAdmin/js/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/phpMyAdmin/lang/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
— Entering directory: http://192.168.137.129/phpMyAdmin/libraries/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```



The images above shows the results for **dirb** `http://192.168.137.129 -o lab2-dirb.txt` command. It scan the web server for common directories/files, display discovered paths in the terminal and save the results to **lab2-dirb.txt**.



The image above show the result for `http://192.168.137.129/mutillidae/` command.



Kali - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

- Kali
- Ubuntu
- Metasploitable2

192.168.137.129/mutillidae/index.php?page=user-info.php&username=admin...

View your details

[Back](#)

Please enter username and password to view account details

Name

Password

[View Account Details](#)

Dont have an account? [Please register here](#)

Error: Failure is always an option and this situation proves it	
Line	126
Code	0
File	/var/www/mutillidae/user-info.php
Message	Error executing query: Table 'metasploit.accounts' doesn't exist
Trace	#0 /var/www/mutillidae/index.php(469): include() #1 (main)
Diagnostic Information	SELECT * FROM accounts WHERE username='admin' AND password='password'

Did you [setup/reset the DB?](#)

OWASP Top 10

Others

Documentation

Resources

Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these [Mozilla Add-ons](#)

@webpwnized

Mutillidae Channel

Kali - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

- Kali
- Ubuntu
- Metasploitable2

192.168.137.129/mutillidae/index.php?page=register.php

Mutillidae: Born to be Hacked

Version: 2.1.19 Security Level: 0 (Hosed) Hints: Disabled (0 - I try harder) Not Logged In

Home Login/Register Toggle Hints Toggle Security Reset DB View Log View Captured Data

Register for an Account

[Back](#)

Please choose your username, password and signature

Username

Password

Confirm Password

Signature

[Create Account](#)

Core Controls

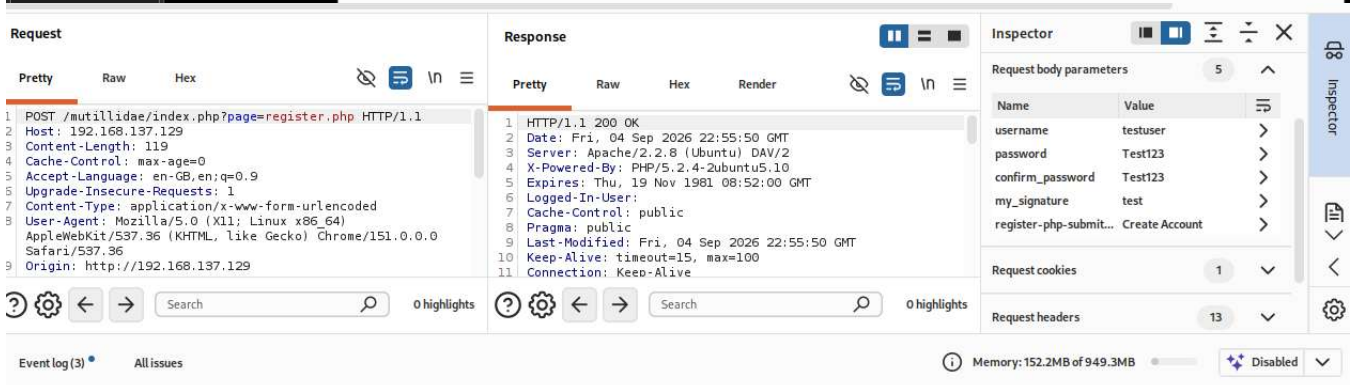
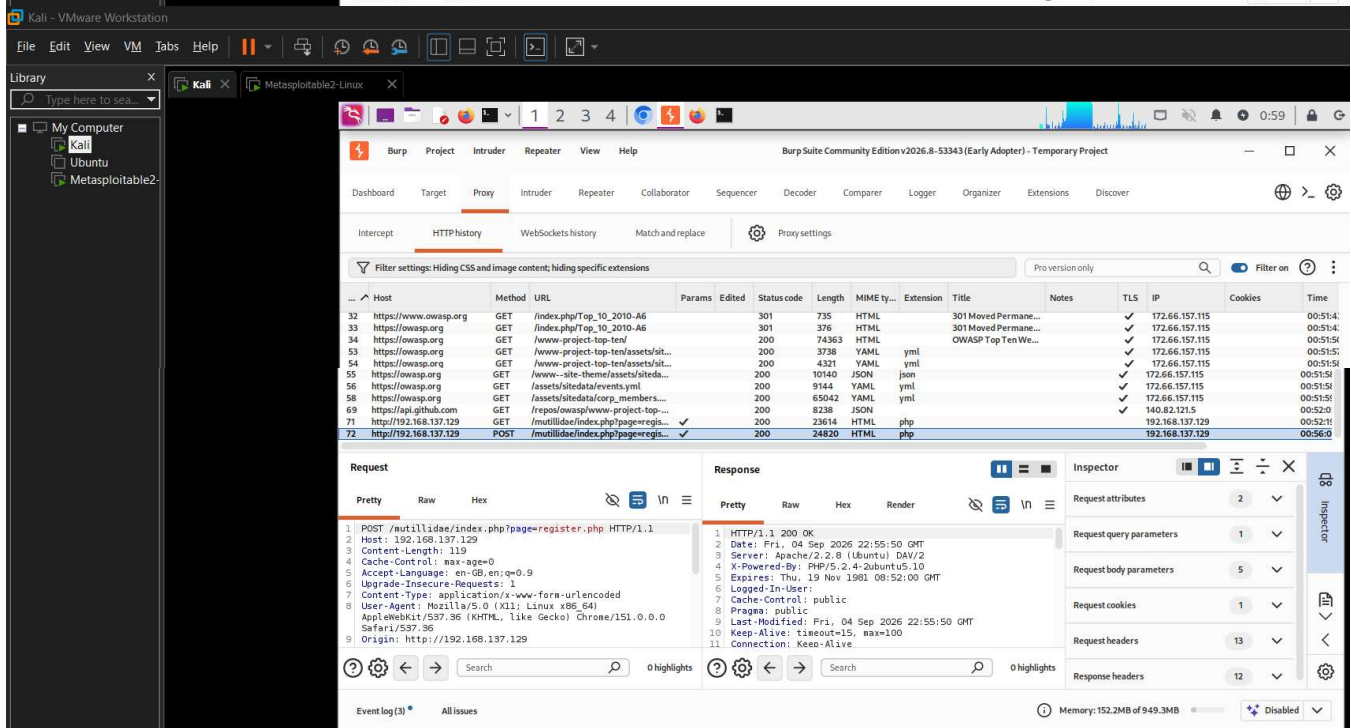
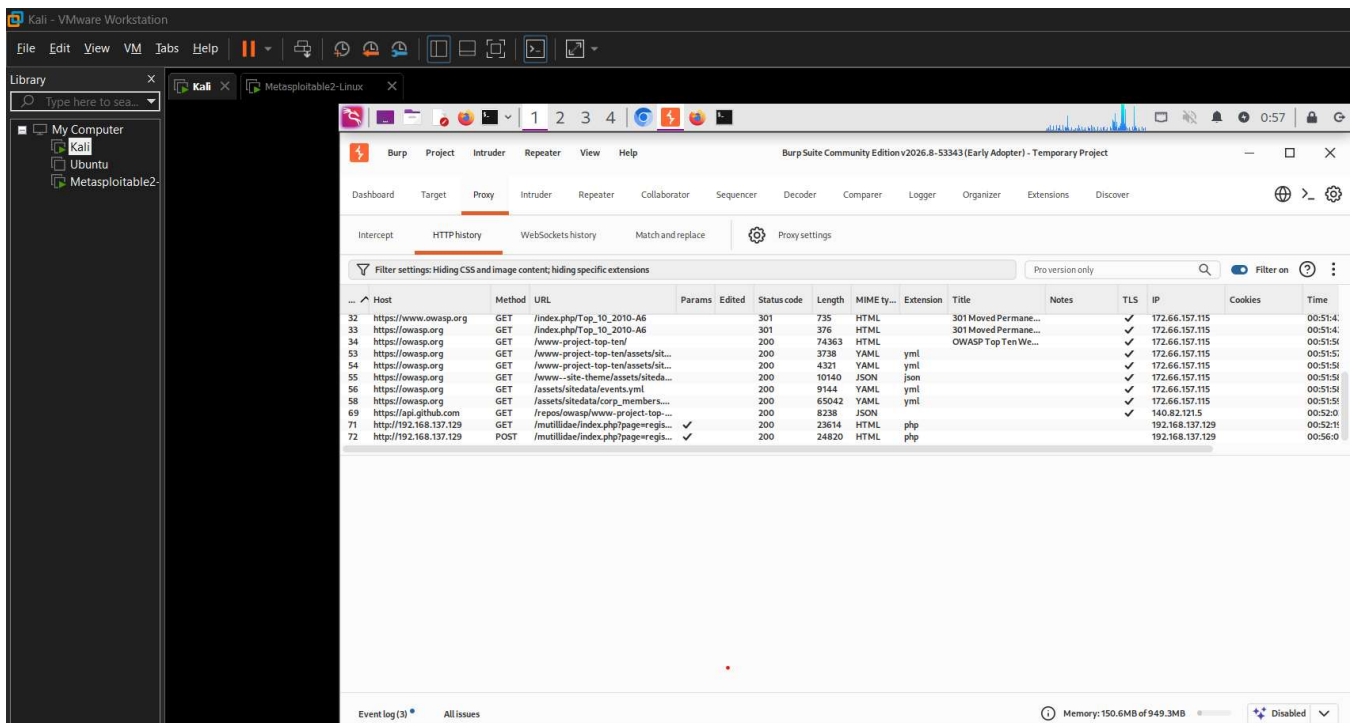
OWASP Top 10

Others

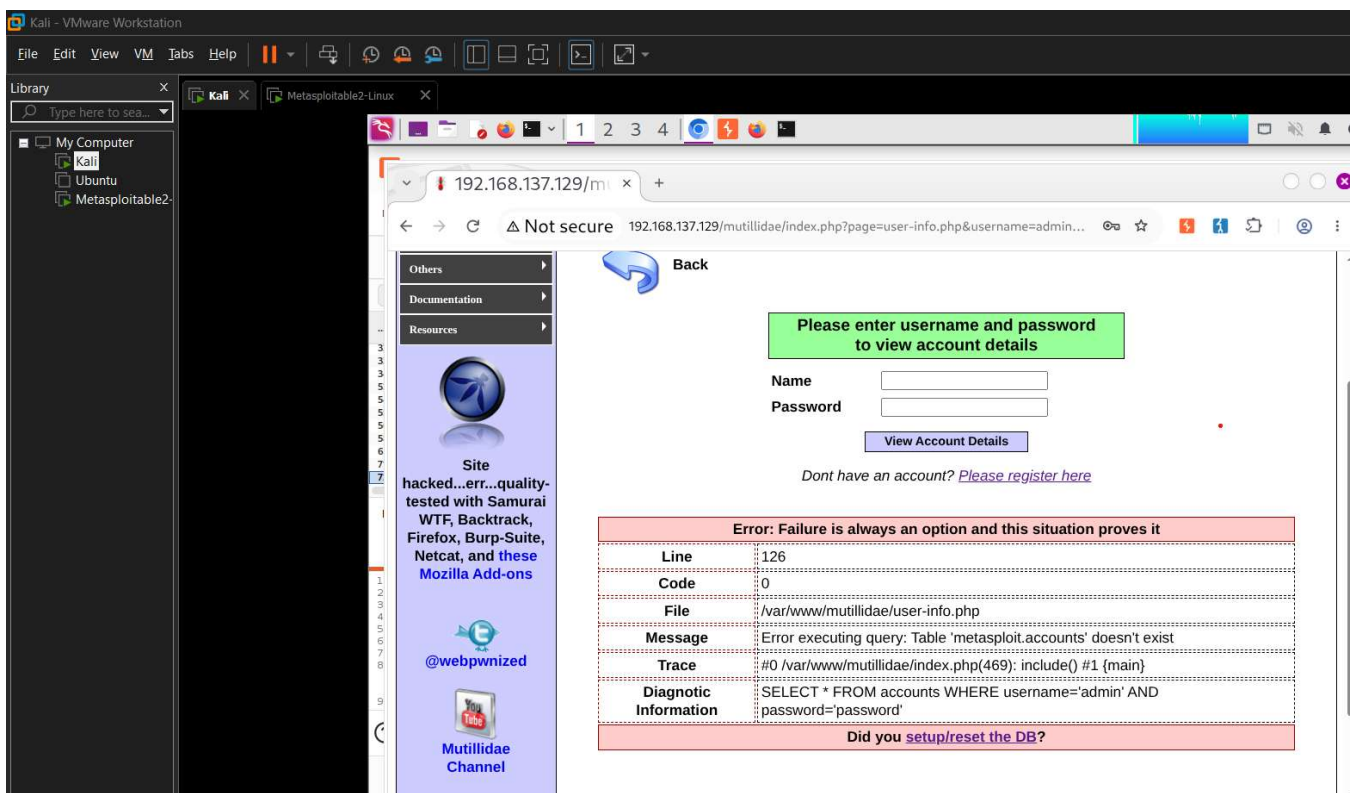
Documentation

Resources

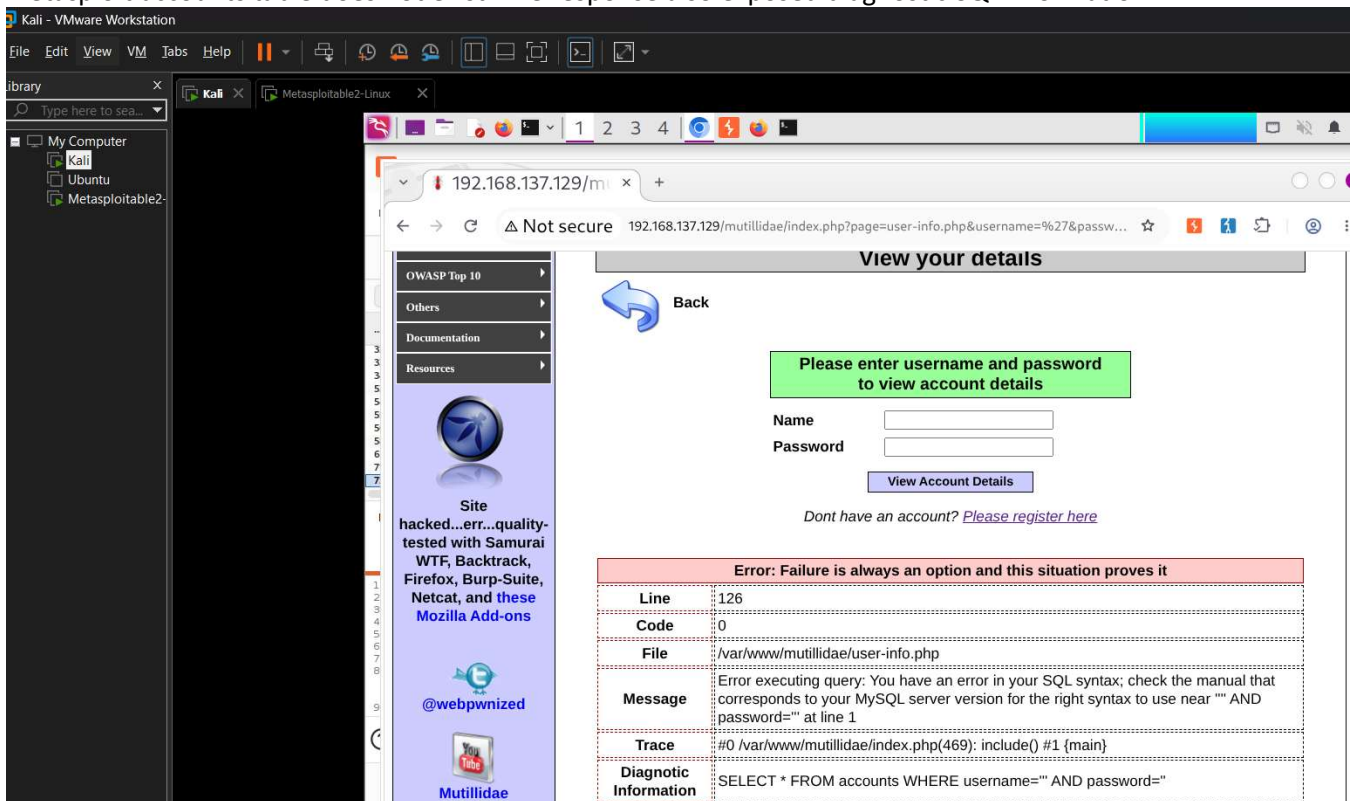
Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these [Mozilla Add-ons](#)



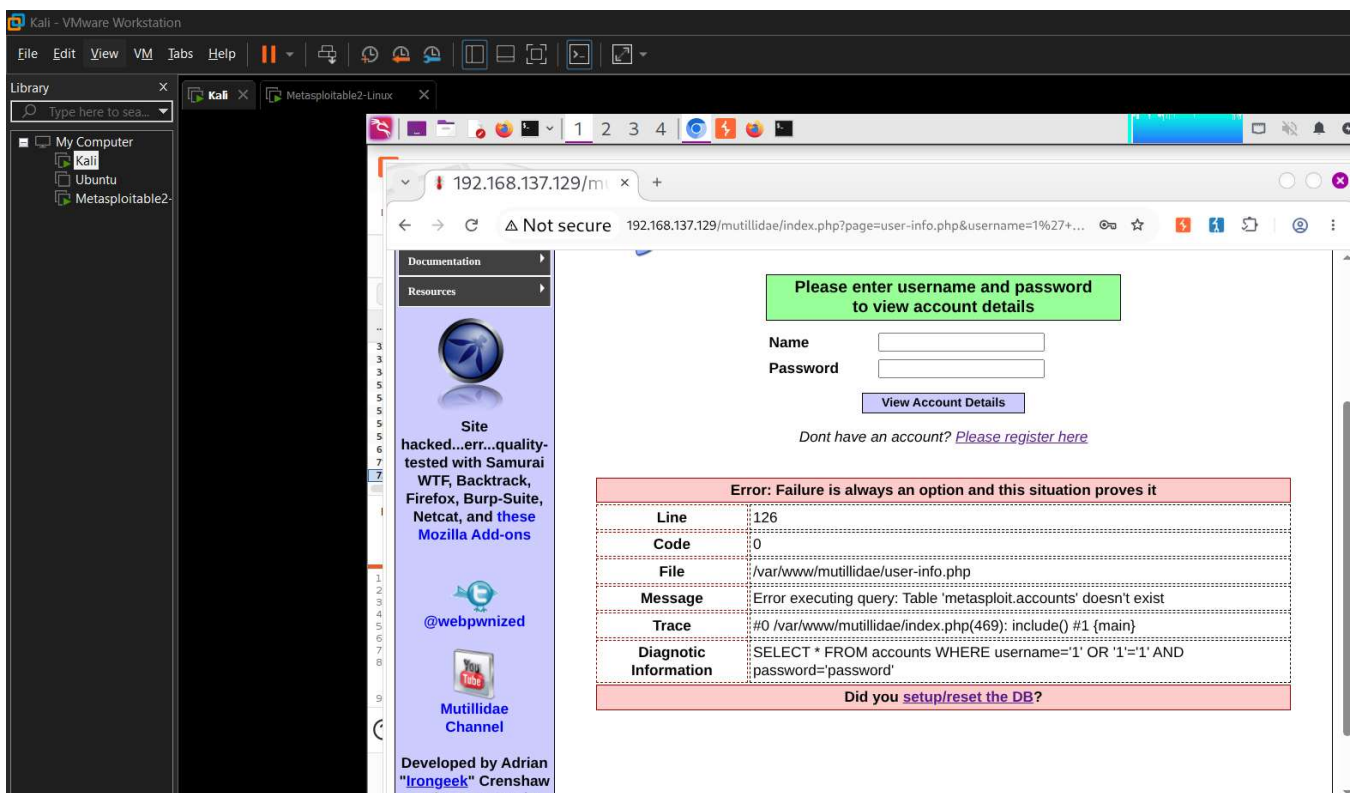
The image above show the result for the step 21, the lab requires at least three inputs with their page, parameter, method, and normal value and they are all shown above.



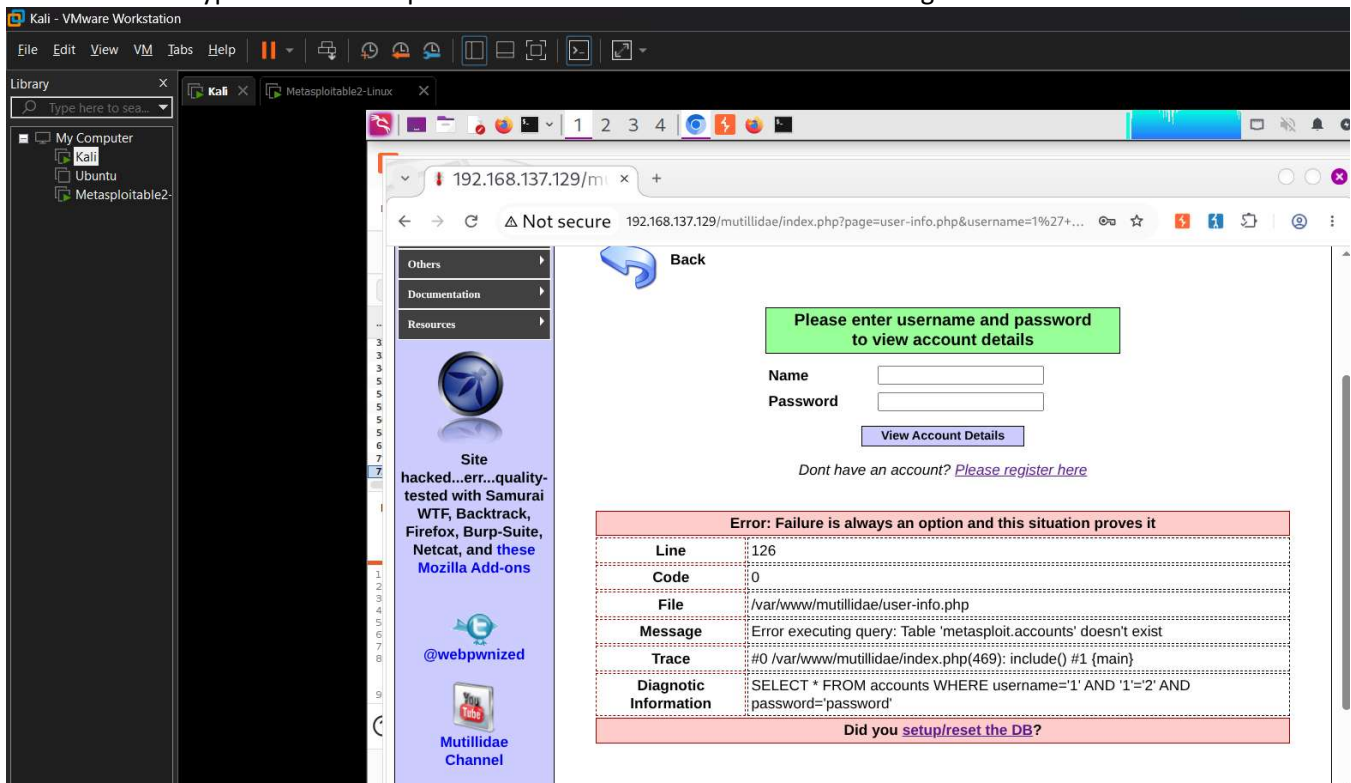
The image above show the result for the step 22. **Baseline observation:** A normal username value (admin) was submitted to the View Your Details function. The application returned a database error stating that the metasploit.accounts table does not exist. The response also exposed diagnostic SQL information.



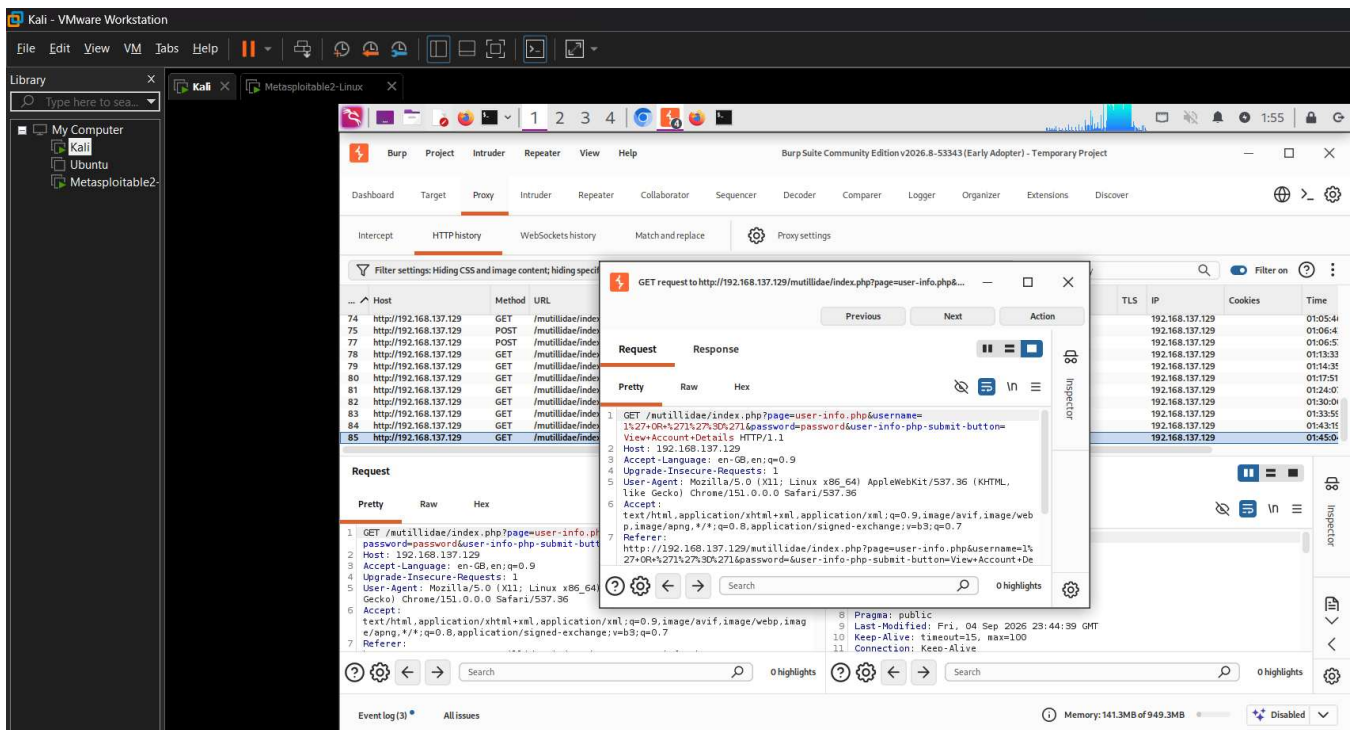
The image above shows the result for step 23. **Single-quote test observation:** A single quote was submitted through the approved username parameter. Unlike the baseline response, the application returned a SQL syntax error. The diagnostic information exposed the resulting SQL statement, indicating that the user-controlled input is being incorporated into the database query.



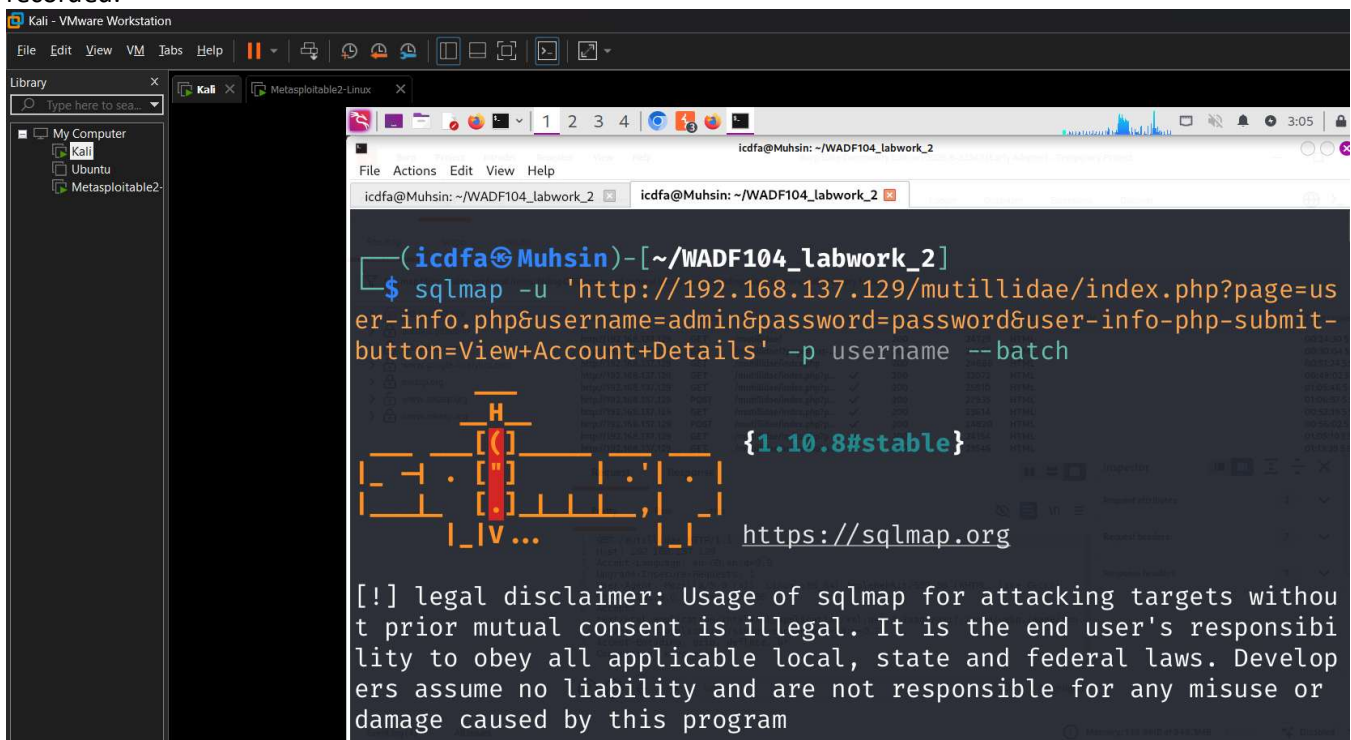
The image above show the result for step 24, **1' OR '1'='1**. The true condition was submitted with a normal password value. The application incorporated the supplied expression into the SQL query and returned a database-table error. The false condition produced a similar database-table error. Therefore, no successful authentication bypass or clear response difference was observed in this configuration.



The image above show the result for step 24, **1' AND '1'='2**. The false condition (**1' AND '1'='2**) was submitted through the username parameter. The application returned a database-table error stating that the metasploit.accounts table does not exist. No successful account retrieval or authentication bypass was observed.

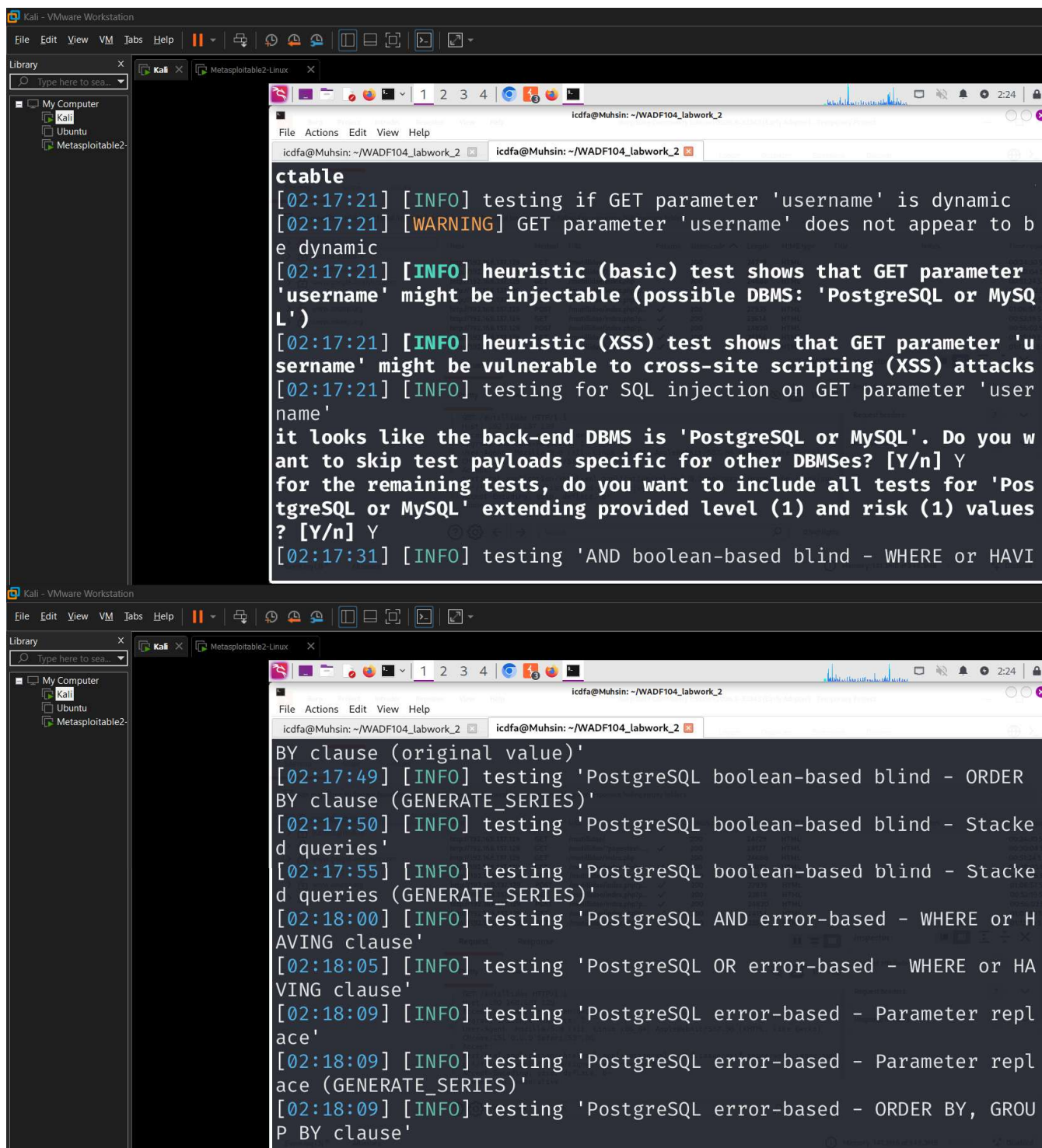


The image above shows the result for step 25. The request was sent using the GET method to /mutillidae/index.php. The username parameter contained the test input, while the password and submit-button parameters were also included. The request returned HTTP 200 OK. Session/cookie values were not recorded.




```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploit2
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
[*] starting @ 02:16:38 /2026-09-05/
[02:16:38] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own
('PHPSESSID=99649faab68 ... e5f28bb78a'). Do you want to use those
[Y/n] Y
[02:17:00] [INFO] checking if the target is protected by some kind
of WAF/IPS
[02:17:00] [INFO] testing if the target URL content is stable
[02:17:01] [INFO] target URL content is stable
[02:17:01] [INFO] testing if GET parameter 'page' is dynamic
[02:17:01] [INFO] GET parameter 'page' appears to be dynamic
[02:17:01] [WARNING] heuristic (basic) test shows that GET paramet
er 'page' might not be injectable
[02:17:01] [INFO] heuristic (XSS) test shows that GET parameter 'p
age' might be vulnerable to cross-site scripting (XSS) attacks
[02:17:01] [INFO] heuristic (FI) test shows that GET parameter 'pa
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploit2
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
[02:17:01] [INFO] testing for SQL injection on GET parameter 'page'
[02:17:01] [INFO] testing 'AND boolean-based blind - WHERE or HAVI
NG clause'
[02:17:01] [WARNING] reflective value(s) found and filtering out
[02:17:02] [INFO] testing 'boolean-based blind - parameter replace
(original value)'
[02:17:02] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, H
AVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[02:17:02] [INFO] testing 'PostgreSQL AND error-based - WHERE or H
AVING clause'
[02:17:03] [INFO] testing 'Microsoft SQL Server/Sybase AND error-b
ased - WHERE or HAVING clause (IN)'
[02:17:03] [INFO] testing 'Oracle AND error-based - WHERE or HAVIN
G clause (XMLType)'
[02:17:04] [INFO] testing 'H2 AND error-based - WHERE, HAVING, ORD
ER BY or GROUP BY clause (CAST)'
```



The images above shows the results for step 26.

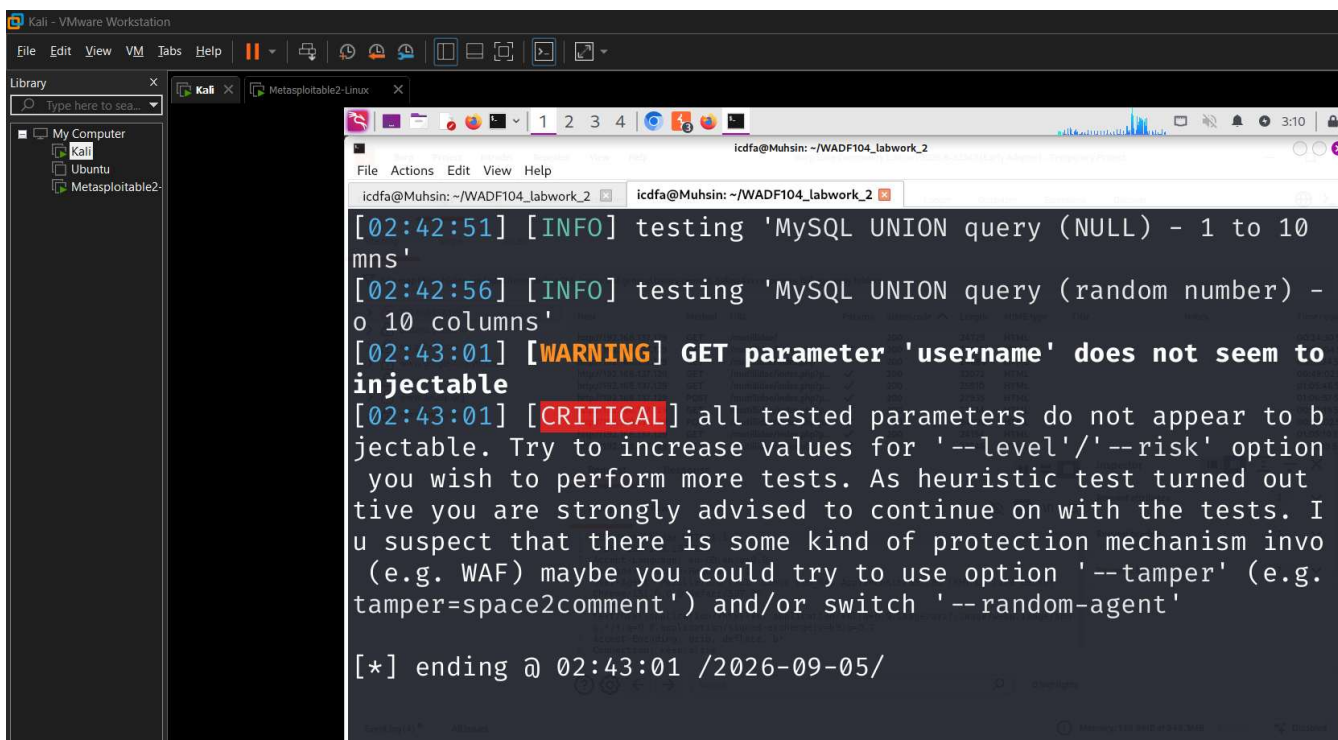
```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2
Kali x Metasploitable2-Linux x
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
icdfa@Muhsin: ~/WADF104_labwork_2
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$ sqlmap -u 'http://192.168.137.129/mutillidae/index.php?page=user-info.php&username=admin&password=password&user-info-php-submit-button=View+Account+Details' -p username --level=1 --risk=1 --batch
{1.10.8#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2
Kali x Metasploitable2-Linux x
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
icdfa@Muhsin: ~/WADF104_labwork_2
[*] starting @ 02:27:22 /2026-09-05/
[02:27:23] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own
('PHPSESSID=bb8ba24ce7f...76006bf43b'). Do you want to use those
[Y/n] Y
[02:27:23] [INFO] testing if the target URL content is stable
[02:27:23] [INFO] target URL content is stable
[02:27:23] [INFO] heuristic (basic) test shows that GET parameter
'username' might be injectable (possible DBMS: 'MySQL')
[02:27:23] [INFO] heuristic (XSS) test shows that GET parameter 'u
sername' might be vulnerable to cross-site scripting (XSS) attacks
[02:27:23] [INFO] testing for SQL injection on GET parameter 'user
name'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip te
st payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MyS
```



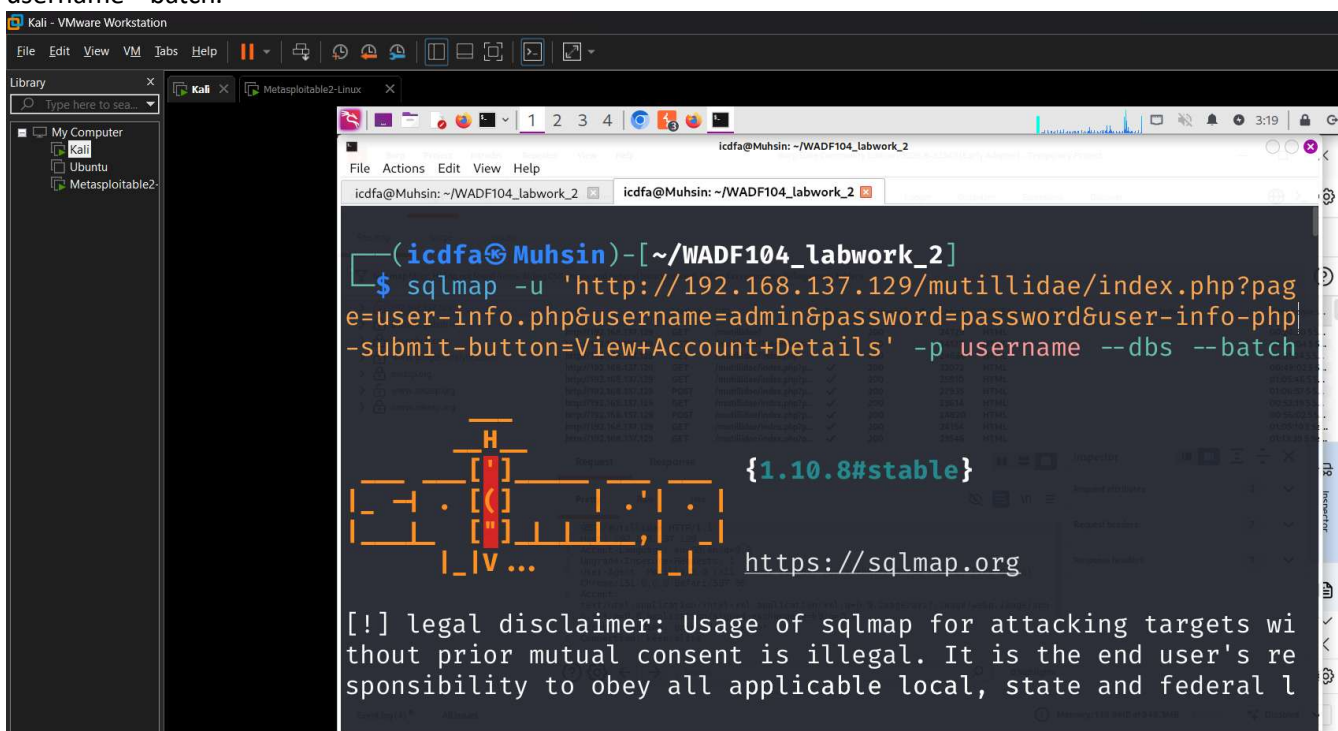
```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali
Metasploitable2-Linux
icdffa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdffa@Muhsin: ~/WADF104_labwork_2
icdffa@Muhsin: ~/WADF104_labwork_2
QL' extending provided level (1) and risk (1) values? [Y/n] Y
[02:27:24] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[02:27:24] [WARNING] reflective value(s) found and filtering out
[02:27:25] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[02:27:25] [INFO] testing 'Generic inline queries'
[02:27:25] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[02:27:30] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[02:27:33] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[02:27:38] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause'
[02:27:45] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali
Metasploitable2-Linux
icdffa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdffa@Muhsin: ~/WADF104_labwork_2
icdffa@Muhsin: ~/WADF104_labwork_2
NCHMARK - comment)'
[02:30:58] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (heavy query - comment)'
[02:31:00] [INFO] testing 'MySQL < 5.0.12 OR time-based blind (BENCHMARK - comment)'
[02:31:03] [INFO] testing 'MySQL > 5.0.12 OR time-based blind (heavy query - comment)'
[02:31:06] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind'
[02:31:09] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind (comment)'
[02:31:12] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind (query SLEEP)'
[02:31:16] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind (query SLEEP - comment)'
[02:31:19] [INFO] testing 'MySQL AND time-based blind (ELT)'
[02:31:23] [INFO] testing 'MySQL OR time-based blind (ELT)'
[02:31:27] [INFO] testing 'MySQL AND time-based blind (ELT - comment)'
```

```
[02:42:51] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 mns'
[02:42:56] [INFO] testing 'MySQL UNION query (random number) - 0 to 10 columns'
[02:43:01] [WARNING] GET parameter 'username' does not seem to injectable
[02:43:01] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' option you wish to perform more tests. As heuristic test turned out negative you are strongly advised to continue on with the tests. I suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. tamper=space2comment') and/or switch '--random-agent'
[*] ending @ 02:43:01 /2026-09-05/
```

The images above shows the results for step 27: `sqlmap -u 'http://192.168.137.129/mutillidae/index.php?page=user-info.php&username=admin&password=password&user-info-php-submit-button=View+Account+Details' -p username --batch`.



```
(icdfa@Muhsin)-[~/WADF104_labwork_2]
$ sqlmap -u 'http://192.168.137.129/mutillidae/index.php?page=user-info.php&username=admin&password=password&user-info-php-submit-button=View+Account+Details' -p username --dbs --batch

{1.10.8#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2-
Kali
Metasploitable2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
[*] starting @ 03:14:12 /2026-09-05/
[03:14:12] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its
own ('PHPSESSID=c5dc7fe31d2 ... fb87aa5238'). Do you want to us
e those [Y/n] Y
[03:14:12] [INFO] testing if the target URL content is stable
[03:14:13] [INFO] target URL content is stable
[03:14:13] [INFO] heuristic (basic) test shows that GET parame
ter 'username' might be injectable (possible DBMS: 'MySQL')
[03:14:13] [INFO] heuristic (XSS) test shows that GET paramete
r 'username' might be vulnerable to cross-site scripting (XSS)
attacks
[03:14:13] [INFO] testing for SQL injection on GET parameter '
username'
it looks like the back-end DBMS is 'MySQL'. Do you want to ski
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2-
Kali
Metasploitable2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
[03:14:13] [INFO] testing 'AND boolean-based blind - WHERE or
HAVING clause'
[03:14:13] [WARNING] reflective value(s) found and filtering o
ut
[03:14:14] [INFO] testing 'Boolean-based blind - Parameter rep
lace (original value)'
[03:14:14] [INFO] testing 'Generic inline queries'
[03:14:14] [INFO] testing 'AND boolean-based blind - WHERE or
HAVING clause (MySQL comment)'
[03:14:17] [INFO] testing 'OR boolean-based blind - WHERE or H
AVING clause (MySQL comment)'
[03:14:20] [INFO] testing 'OR boolean-based blind - WHERE or H
AVING clause (NOT - MySQL comment)'
[03:14:24] [INFO] testing 'MySQL RLIKE boolean-based blind - W
HERE, HAVING, ORDER BY or GROUP BY clause'
[03:14:29] [INFO] testing 'MySQL AND boolean-based blind - WHE
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2

icdfe@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfe@Muhsin: ~/WADF104_labwork_2
icdfe@Muhsin: ~/WADF104_labwork_2
E, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[03:14:38] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[03:14:44] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[03:14:48] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[03:14:53] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[03:14:57] [INFO] testing 'MySQL boolean-based blind - Parameter replace (MAKE_SET)'
[03:14:57] [INFO] testing 'MySQL boolean-based blind - Parameter replace (MAKE_SET - original value)'
[03:14:58] [INFO] testing 'MySQL boolean-based blind - Parameter replace (ELT)'
[03:14:58] [INFO] testing 'MySQL boolean-based blind - Parameter
```

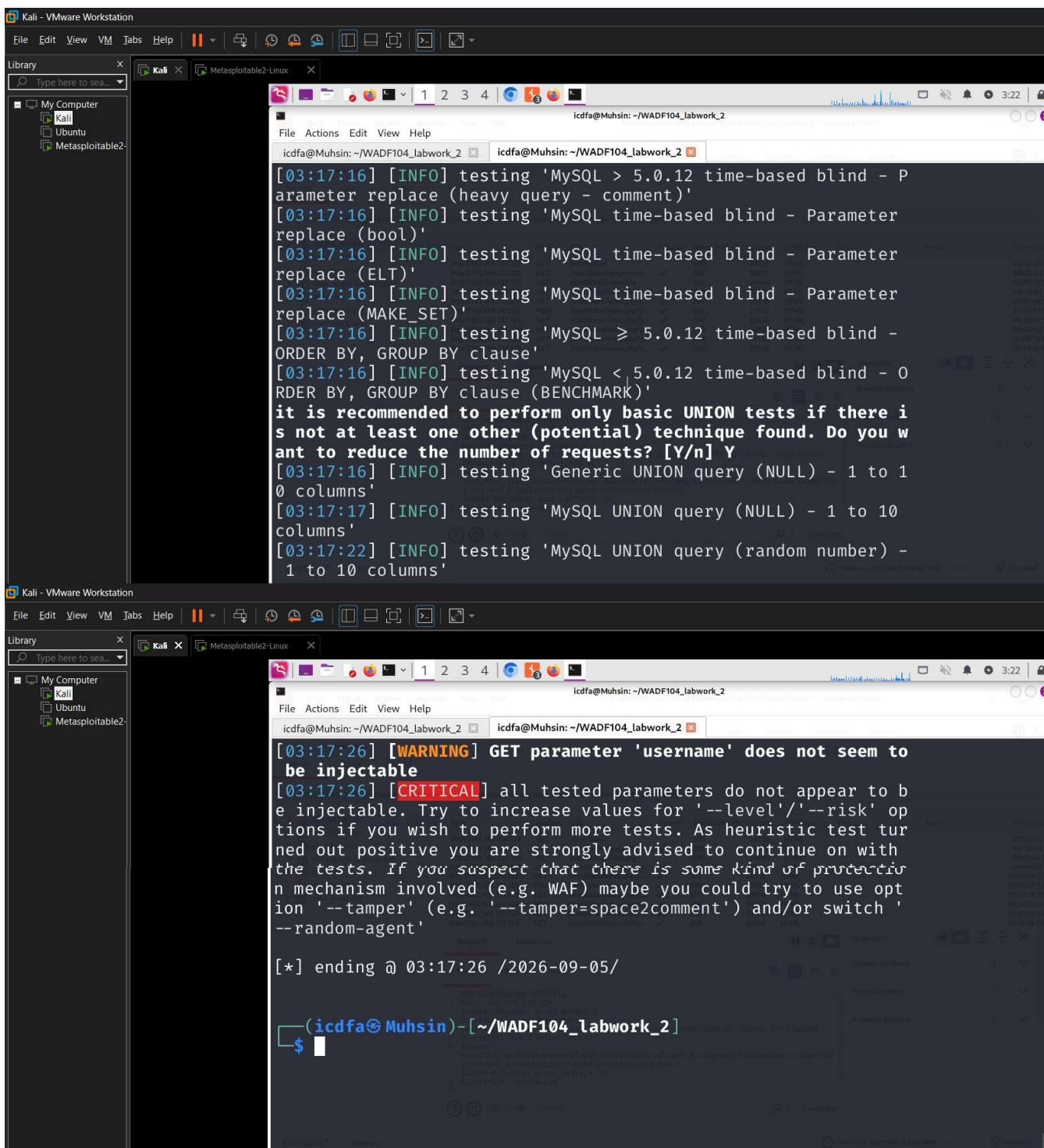
```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploitable2

icdfe@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfe@Muhsin: ~/WADF104_labwork_2
icdfe@Muhsin: ~/WADF104_labwork_2
E, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[03:15:06] [INFO] testing 'MySQL ≥ 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[03:15:09] [INFO] testing 'MySQL ≥ 8.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UUID_TO_BIN)'
[03:15:12] [INFO] testing 'MySQL ≥ 8.0 OR error-based - WHERE or HAVING clause (UUID_TO_BIN)'
[03:15:15] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[03:15:18] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[03:15:21] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[03:15:24] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[03:15:26] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE
```



```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali
Metasploitable2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
[03:16:01] [INFO] testing 'MySQL ≥ 5.5 error-based - Parameter replace (EXP)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.6 error-based - Parameter replace (GTID_SUBSET)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.7.8 error-based - Parameter replace (JSON_KEYS)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.0 error-based - Parameter replace (FLOOR)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.1 error-based - Parameter replace (UPDATEXML)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.1 error-based - Parameter replace (EXTRACTVALUE)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.5 error-based - ORDER BY, GROUP BY clause (BIGINT UNSIGNED)'
[03:16:01] [INFO] testing 'MySQL ≥ 5.5 error-based - ORDER BY, GROUP BY clause (EXP)'
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali
Metasploitable2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
(query SLEEP)'
[03:16:20] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (SLEEP)'
[03:16:24] [INFO] testing 'MySQL ≥ 5.0.12 OR time-based blind (SLEEP)'
[03:16:27] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (SLEEP - comment)'
[03:16:28] [INFO] testing 'MySQL ≥ 5.0.12 OR time-based blind (SLEEP - comment)'
[03:16:31] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP - comment)'
[03:16:33] [INFO] testing 'MySQL ≥ 5.0.12 OR time-based blind (query SLEEP - comment)'
[03:16:34] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (BENCHMARK)'
[03:16:37] [INFO] testing 'MySQL > 5.0.12 AND time-based blind
```

The images above shows the results for step 28: **sqlmap -u 'http://<target-ip>/mutillidae/index.php?page=user-info.php&username=admin&password=password&user-info-php-submit-button=View+Account+Details' -p username --dbs --batch.**

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploit2-Linux
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
icdfa@Muhsin: ~/WADF104_labwork_2
$ sqlmap -u 'http://192.168.137.129/mutillidae/index.php?page=user-info.php&username=admin&password=password&user-info-php-submit-button=View+Account+Details' -p username -D metasploit --tables --batch
{1.10.8#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 03:30:07 /2026-09-05/
[03:30:07] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('PHPSES
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali
Ubuntu
Metasploit2-Linux
Metasploit2-Linux
icdfa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdfa@Muhsin: ~/WADF104_labwork_2
icdfa@Muhsin: ~/WADF104_labwork_2
SID=46494a40588 ... 067752d6ff'). Do you want to use those [Y/n] Y
[03:30:08] [INFO] testing if the target URL content is stable
[03:30:08] [INFO] target URL content is stable
[03:30:08] [INFO] heuristic (basic) test shows that GET parameter 'username' might be injectable (possible DBMS: 'MySQL')
[03:30:08] [INFO] heuristic (XSS) test shows that GET parameter 'username' might be vulnerable to cross-site scripting (XSS) attacks
[03:30:08] [INFO] testing for SQL injection on GET parameter 'username' it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[03:30:08] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[03:30:08] [WARNING] reflective value(s) found and filtering out
[03:30:09] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[03:30:10] [INFO] testing 'Generic inline queries'
[03:30:10] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[03:30:14] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali x Metasploitable2-Linux x
icdffa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdffa@Muhsin: ~/WADF104_labwork_2 x icdffa@Muhsin: ~/WADF104_labwork_2 x
[03:31:25] [INFO] testing 'MySQL ≥ 8.0 AND error-based - WHERE, HAVING, OR
DER BY or GROUP BY clause (UUID_TO_BIN)'
[03:31:30] [INFO] testing 'MySQL ≥ 8.0 OR error-based - WHERE or HAVING cl
ause (UUID_TO_BIN)'
[03:31:34] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, OR
DER BY or GROUP BY clause (EXTRACTVALUE)'
[03:31:38] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORD
ER BY or GROUP BY clause (EXTRACTVALUE)'
[03:31:43] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, OR
DER BY or GROUP BY clause (BIGINT UNSIGNED)'
[03:31:47] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING cl
ause (BIGINT UNSIGNED)'
[03:31:51] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, OR
DER BY or GROUP BY clause (EXP)'
[03:31:56] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING cl
ause (EXP)'
[03:32:00] [INFO] testing 'MySQL ≥ 5.7.8 AND error-based - WHERE, HAVING,
ORDER BY or GROUP BY clause (JSON_KEYS)'
[03:32:06] [INFO] testing 'MySQL ≥ 5.7.8 OR error-based - WHERE or HAVING
clause (JSON_KEYS)'
[03:32:10] [INFO] testing 'MySQL ≥ 5.0 AND error-based - WHERE, HAVING, OR
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
Library
x
Type here to sea...
My Computer
Kali
Ubuntu
Metasploitable2
Kali x Metasploitable2-Linux x
icdffa@Muhsin: ~/WADF104_labwork_2
File Actions Edit View Help
icdffa@Muhsin: ~/WADF104_labwork_2 x icdffa@Muhsin: ~/WADF104_labwork_2 x
[03:32:39] [INFO] testing 'MySQL OR error-based - WHERE or HAVING clause (F
LOOR)'
[03:32:42] [INFO] testing 'MySQL ≥ 5.1 error-based - PROCEDURE ANALYSE (EX
TRACTVALUE)'
[03:32:45] [INFO] testing 'MySQL ≥ 5.5 error-based - Parameter replace (BI
GINT UNSIGNED)'
[03:32:45] [INFO] testing 'MySQL ≥ 5.5 error-based - Parameter replace (EX
P)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.6 error-based - Parameter replace (GT
ID_SUBSET)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.7.8 error-based - Parameter replace (
JSON_KEYS)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.0 error-based - Parameter replace (FL
OOR)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.1 error-based - Parameter replace (UP
DATEXML)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.1 error-based - Parameter replace (EX
TRACTVALUE)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.5 error-based - ORDER BY, GROUP BY cl
ause (BIGINT UNSIGNED)'
[03:32:46] [INFO] testing 'MySQL ≥ 5.5 error-based - ORDER BY, GROUP BY cl
```



```
clause (JSON_KEYS)'
[03:32:47] [INFO] testing 'MySQL >= 5.0 error-based - ORDER BY, GROUP BY clause (FLOOR)'
[03:32:47] [INFO] testing 'MySQL >= 5.1 error-based - ORDER BY, GROUP BY clause (EXTRACTVALUE)'
[03:32:48] [INFO] testing 'MySQL >= 5.1 error-based - ORDER BY, GROUP BY clause (UPDATEXML)'
[03:32:48] [INFO] testing 'MySQL >= 4.1 error-based - ORDER BY, GROUP BY clause (FLOOR)'
[03:32:48] [INFO] testing 'MySQL inline queries'
[03:32:48] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)'
[03:32:51] [INFO] testing 'MySQL >= 5.0.12 stacked queries'
[03:32:55] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)'
[03:32:58] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)'
[03:33:02] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[03:33:05] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[03:33:09] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[03:33:14] [INFO] testing 'MySQL >= 5.0.12 OR time-based blind (query SLEEP'

[03:34:45] [INFO] testing 'MySQL < 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[03:34:45] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[03:34:46] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[03:34:53] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[03:35:01] [WARNING] GET parameter 'username' does not seem to be injectable
[03:35:01] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. As heuristic test turned out positive you are strongly advised to continue on with the tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'

[*] ending @ 03:35:01 /2026-09-05/
```

The images above shows the result for 29. SQLMap was used to attempt table enumeration against the metasploit database through the approved `username` parameter. Although the heuristic test initially suggested the parameter might be injectable, the final SQLMap result did not confirm injection.

QUESTIONS

1. What is the difference between GET and POST?

Answer: **GET** sends data as part of the URL, usually through query parameters. It is commonly used to request or retrieve information while **POST** sends data in the HTTP request body and is commonly used when submitting information to the server, such as form data.

2. What is a parameter?

Answer: A **parameter** is a value sent to a web application as part of a request. It provides information that the application uses to process the request. Parameters can appear in the URL of a GET request or in the body of a POST request.

3. Why should cookies be hidden in reports?

Answer: Cookies should be hidden because they may contain **session information or other sensitive values**. Exposing them in a report could allow someone to misuse the session or gain unauthorized access. The lab specifically instructs us to record cookie names but not secret values.

4. What is multipart/form-data?

Answer: is an HTTP content type used to submit form data, especially when a file is included. It separates the different parts of the request, allowing the server to receive both normal form fields and uploaded files.

5. Why are extension and MIME type different?

Answer: A file extension and MIME type can be different because they are separate pieces of information. The extension is part of the filename, while the MIME type is supplied in the HTTP request to describe the file's content type. Therefore, relying only on either one can be unsafe when validating uploaded files.

6. Why is trusting client Content-Type weak?

Answer: Trusting the client-supplied Content-Type is weak because the value can be modified by the client before the request reaches the server. A secure application should perform server-side validation of the file type and content rather than relying only on the MIME type provided by the client.

7. Why should uploads be stored outside an executable web directory?

Answer: Uploaded files should be stored outside an executable web directory to prevent potentially malicious files from being executed by the server. Alternatively, the upload directory should be configured to disable script execution.

8. What kind of information did Nikto report?

Answer: Nikto reported information about the web server configuration, server technologies and versions, accessible resources, and potentially insecure settings. These findings can help identify areas that require further security review.

9. What do 200, 301/302, 403 and 404 generally mean in DIRB output?

Answer: In DIRB results, a 200 status generally indicates that the resource was successfully accessed. 301 or 302 indicates a redirection. 403 indicates that the resource exists but access is forbidden, while 404 indicates that the requested resource was not found.

10. Why establish a baseline before SQL tests?

Answer: Establishing a baseline before SQL testing helps us understand the application's normal response to valid input. This provides a reference point for comparing the application's behavior when SQL test inputs are introduced and helps identify meaningful differences.

11. What happened with a single quote?

Answer: When a single quote (') was entered in the username parameter, the application returned a SQL syntax error. This indicated that user-supplied input was being incorporated into the SQL query and that the application was exposing database error information.

12. How did the true and false conditions differ?

Answer: The true and false SQL conditions were designed to produce different logical outcomes. The true condition used 1' OR '1'='1, while the false condition used 1' AND '1'='2. In our test, both produced the same database-table error, so no successful authentication bypass was confirmed.

13. What did SQLMap automate that you already observed manually?

Answer: SQLMap automated the process of testing the selected parameter for SQL injection by sending various test requests and analyzing the application's responses. Unlike the manual tests, which required us to enter and compare individual payloads, SQLMap performed these tests automatically. In our test, SQLMap did not confirm the username parameter as injectable.

14. Why do prepared statements stop input from being interpreted as SQL syntax?

Answer: Prepared statements separate the SQL command from the data supplied by the user. Therefore, user input is treated as data rather than being interpreted as part of the SQL command. This helps prevent SQL injection attacks.

15. Why is authorisation mandatory?

Answer: Authorization is mandatory because security testing should only be performed on systems and applications for which permission has been given. Testing unauthorized systems can cause disruption, expose sensitive information, and may have legal consequences. In this lab, testing was limited to the intentionally vulnerable DVWA and Mutillidae applications provided for the exercise.